Tema 29 · Bloque II | 60 preguntas de test

Control remoto de puesto de usuario y gestión de la resolución de incidencias

Puesto de trabajo y escritorios virtualizados · RDP, VNC, SSH y gestión fuera de banda · CAU e ITIL 4 · Priorización, escalado y SLA · ENS y protección de datos

Enunciado oficial del programa (BOAM n.º 10.032, de 23 de diciembre de 2025): Control remoto de puesto de usuario y gestión de la resolución de incidencias.

EXTENSIÓN
~21.500 palabras · 16 diagramas · 60 preguntas de test

TIEMPO ESTIMADO DE ESTUDIO
19–21 horas (primera vuelta completa, sin contar repasos)

Índice

- [ ] **1. El puesto de usuario y la asistencia técnica remota**
  - [ ] **1.1. Arquitectura y modelos del puesto de trabajo digital**
  - [ ] **1.2. Fundamentos del control remoto**
  - [ ] **1.3. Protocolos y tecnologías de control remoto**
- [ ] **2. Gestión de la resolución de incidencias en los servicios TI**
  - [ ] **2.1. Marcos de referencia para la gestión de servicios TI**
  - [ ] **2.2. El Centro de Atención a Usuarios (CAU)**
  - [ ] **2.3. Proceso de gestión y resolución de incidencias**
  - [ ] **2.4. Gestión de peticiones de servicio y eventos**
- [ ] **3. Marco normativo, seguridad y calidad en la Administración Pública**
  - [ ] **3.1. Seguridad en la asistencia remota**
  - [ ] **3.2. Cumplimiento normativo y Esquema Nacional de Seguridad**
  - [ ] **3.3. Medición y mejora continua del servicio**

Conceptos clave para memorizar

Concepto	Dato clave
Incidencia (ITIL)	**Interrupción no planificada** de un servicio o **reducción de su calidad**. Objetivo de su gestión: **restablecer el servicio lo antes posible**, no averiguar la causa
Problema (ITIL)	**Causa, o causa potencial**, de una o varias incidencias. Su gestión sí busca la **causa raíz** y produce **errores conocidos** y **soluciones temporales** (*workarounds*)
Petición de servicio	Solicitud **prevista y acordada** en la prestación normal del servicio (alta de usuario, restablecer contraseña, instalar software del catálogo). **No hay interrupción**
Evento	**Cambio de estado significativo** de un elemento de configuración o servicio. Tipos: **informativo**, **advertencia** y **excepción**; solo la excepción suele generar incidencia
Prioridad	**Prioridad = impacto × urgencia**. El **impacto** mide a cuánto afecta (personas, servicios, criticidad); la **urgencia**, con qué rapidez se degrada si no se actúa
Escalado funcional	**Horizontal**: se pasa a un grupo con **más conocimiento técnico** (N1 → N2 → N3). No implica más autoridad
Escalado jerárquico	**Vertical**: se avisa a un **nivel de autoridad superior** para decidir, autorizar o aportar recursos. No implica más conocimiento técnico
SLA / OLA / UC	**SLA** con el cliente o usuario del servicio; **OLA** entre equipos **internos** de la propia organización; **UC** (contrato de soporte) con un **proveedor externo**. Los OLA y los UC deben sostener el SLA
RFB (VNC)	**RFC 6143**. Transmite el **framebuffer** (píxeles) y eventos de teclado y ratón; independiente del sistema operativo; **comparte la sesión de consola**. Puerto TCP **5900**
RDP	Microsoft, puertos TCP/UDP **3389**. Transmite **primitivas gráficas y canales virtuales** (no píxeles en bruto); crea por defecto una **sesión independiente** y redirige impresoras, discos y portapapeles
SSH	**Puerto TCP 22**, RFC 4251-4254. Terminal remoto **cifrado y autenticado**, con **túneles** y transferencia de ficheros (SCP/SFTP). Sustituye a **Telnet** (puerto 23, texto en claro)

Concepto	Dato clave
WinRM	Implementación Microsoft de **WS-Management**; puertos **5985** (HTTP) y **5986** (HTTPS). Base de *PowerShell Remoting*
Gestión fuera de banda	**IPMI/BMC** (UDP 623) y **Redfish** (HTTPS/REST): permiten actuar sobre el equipo **apagado o con el sistema operativo caído**, por una vía independiente
Wake-on-LAN	**Paquete mágico** enviado a los puertos UDP **7 o 9** que enciende el equipo por red para parchearlo o darle soporte fuera del horario laboral
Atendido / desatendido	**Atendido**: el usuario está delante y **consiente** cada sesión. **Desatendido**: el agente permite conectarse sin usuario; exige controles reforzados y justificación
VDI / RDSH / DaaS	**VDI**: una máquina virtual completa por usuario. **RDSH**: sesiones múltiples sobre un mismo servidor. **DaaS**: lo anterior consumido como servicio en la nube
Dimensiones ENS	**Disponibilidad, Autenticidad, Integridad, Confidencialidad y Trazabilidad**. Categorías del sistema: **BÁSICA, MEDIA y ALTA** [ENS]
Mínimo privilegio	Cada técnico debe tener **solo** los permisos imprescindibles y **solo** durante el tiempo necesario; se apoya en RBAC, segregación de funciones y elevación temporal
KPI del CAU	**FCR** (resolución en primer contacto), **MTTR** (tiempo medio de restablecimiento), **ASA** (tiempo medio de respuesta), **cumplimiento de SLA**, **tasa de reapertura**, **CSAT**
Base de conocimiento	Convierte cada resolución en **conocimiento reutilizable**; alimenta el autoservicio (NO) y eleva la **FCR** sin aumentar la plantilla

Contenido

Convenciones del documento

Este tema incluye cuatro tipos de **cajas callout** para facilitar el estudio:

> **DATO CLAVE**
> Información de alta densidad memorística.

> **EJERCICIO RESUELTO**
> Problema + solución paso a paso (clasificación de una incidencia, cálculo de una prioridad o de un indicador, elección de un mecanismo de conexión).

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
> Aplicación real de la teoría al entorno municipal (puesto de trabajo del empleado, sede electrónica, Oficinas de Atención a la Ciudadanía, expedientes).

> **RELACIÓN CON OTROS TEMAS**
> Enlace conceptual a otros temas del temario oficial.

Este es un tema **de dos mitades**, y conviene tenerlo presente desde el principio. La primera es **técnica**: cómo se toma control de un puesto de trabajo a distancia, con qué protocolos, por qué puertos y con qué garantías. La segunda es **organizativa**: cómo se gestiona el ciclo de vida de una incidencia dentro de un servicio TI, con qué marcos de referencia y con qué indicadores. La tercera sección cose ambas mitades con el **marco normativo** que las condiciona en una Administración Pública: Esquema Nacional de Seguridad y protección de datos personales. Un opositor que domine solo una de las dos mitades suspende la otra: el temario las une deliberadamente porque en la práctica del CAU van juntas —la asistencia remota es la herramienta con la que se resuelve la incidencia registrada.

Los nombres de **productos concretos** (RDP, VNC, SSH, Intune, ServiceNow, GLPI) aparecen como ejemplos ilustrativos, no como contenido a memorizar por marcas: lo que importa es el **mecanismo**. Sí conviene memorizar, en cambio, los **puertos y números de RFC** citados, porque son datos discretos. Las fuentes se citan con etiquetas breves tipo `[RFC6143]` o `[ITIL4]`; el registro completo está en la pestaña Fuentes.

Caso de referencia usado en todo el tema (contexto Ayuntamiento de Madrid, supuesto simplificado): una **tramitadora de una Oficina de Atención a la Ciudadanía de un distrito** no consigue firmar electrónicamente un expediente con su certificado en tarjeta criptográfica; tiene a

un vecino esperando en el mostrador. Llama al **Centro de Atención a Usuarios (CAU)** del Ayuntamiento, que registra la incidencia, la prioriza, toma el control remoto de su puesto para diagnosticarla y, si no puede resolverla, la escala. Este supuesto concentra casi todas las dificultades del tema: identificación del usuario y del puesto, consentimiento para la asistencia, acceso a datos personales de terceros durante la sesión, priorización con un servicio de cara al público afectado, escalado, cumplimiento de un acuerdo de nivel de servicio, trazabilidad exigida por el ENS y aprovechamiento posterior del conocimiento generado.

---

1. El puesto de usuario y la asistencia técnica remota

1.1. Arquitectura y modelos del puesto de trabajo digital

El **puesto de trabajo digital** (o *puesto de usuario*) es el conjunto de hardware, software, configuración, identidad y servicios que una organización pone a disposición de un empleado para que realice su trabajo. No es solo «el ordenador»: es un **servicio compuesto** cuya disponibilidad depende del equipo físico, del sistema operativo y su configuración, de las aplicaciones, de la conectividad de red, del directorio de identidades, de la impresión, del almacenamiento y de los servicios corporativos a los que accede.

Esta definición tiene una consecuencia práctica inmediata para la gestión de incidencias: cuando un usuario dice *«no me funciona el ordenador»*, el fallo puede estar en cualquiera de esas capas, y el trabajo del primer nivel de soporte consiste precisamente en **acotar en qué capa está** antes de tocar nada.

> DATO CLAVE
> El puesto de usuario es un **servicio compuesto por capas**: hardware → firmware → sistema operativo → configuración y directivas → aplicaciones → identidad y permisos → conectividad → servicios corporativos. Un fallo percibido por el usuario como único puede originarse en cualquiera de ellas, y el diagnóstico consiste en **descartar capas de abajo arriba o de arriba abajo**, no en probar soluciones al azar [ITIL4].

El **ciclo de vida del puesto** se gestiona en cinco fases, todas ellas susceptibles de automatización remota (§1.3.4):

Fase	Contenido	Herramientas típicas
Aprovisionamiento	Adquisición, alta en inventario, instalación de la imagen base, alta en el dominio y en el directorio	PXE/UEFI, imágenes maestras, MDT, Intune Autopilot [UEFI] [MS-INTUNE]
Configuración	Aplicación de directivas, cifrado de disco, despliegue del catálogo de software, personalización por perfil	GPO, Intune, Ansible, SCCM [MS-GPO] [ANSIBLE]
Operación	Parcheo, actualización de antivirus, inventario continuo, monitorización	WSUS, repositorios internos, agentes de inventario [WSUS] [UEM]
Soporte	Atención de incidencias y peticiones, asistencia remota, sustitución de piezas	CAU, herramientas de control remoto (§1.3.3)
Retirada	Baja de inventario, **borrado seguro** del almacenamiento, reasignación o destrucción certificada	Herramientas de borrado, procedimientos ENS de gestión de soportes [ENS]

RELACIÓN CON OTROS TEMAS

La **administración del sistema operativo y del software de base** —actualización, mantenimiento y reparación del SO— es el objeto del **Tema 27**, y las **características y elementos constitutivos de los sistemas operativos** (Windows, Unix y Linux) los del **Tema 14**. Aquí interesa solo lo que afecta a la asistencia remota y al soporte del puesto.

1.1.1. Entornos de escritorio tradicionales y virtualizados

Existen cuatro grandes modelos de puesto, y la elección entre ellos condiciona por completo cómo se le da soporte:

1. Escritorio tradicional (cliente pesado o *fat client*). El equipo físico ejecuta localmente el sistema operativo y las aplicaciones, y almacena datos en su disco. Es el modelo más extendido y el más exigente para el soporte: cada equipo es un sistema distinto que hay que inventariar, parchear y reparar individualmente. Su ventaja es la autonomía —funciona sin red— y el aprovechamiento de la potencia local.

2. Infraestructura de escritorio virtual (VDI, *Virtual Desktop Infrastructure*). Cada usuario dispone de una **máquina virtual completa** ejecutándose en el centro de proceso de datos; en su mesa hay un **cliente ligero** (*thin client*), un cliente cero (*zero client*) o un PC reutilizado que solo ejecuta el cliente de conexión. Se distinguen dos variantes decisivas:

- **VDI persistente**: cada usuario tiene «su» máquina virtual, que conserva cambios y personalización entre sesiones. Se parece a un PC, pero centralizado; consume más almacenamiento.
- **VDI no persistente**: la máquina se crea a partir de una **imagen maestra** (*golden image*) en cada inicio de sesión y se destruye al cerrarla; la personalización y los datos se conservan aparte mediante perfiles y redirección de carpetas. Es más barata y homogénea, y tiene un efecto notable en el soporte: **muchas incidencias se resuelven simplemente cerrando y volviendo a abrir la sesión**, porque el escritorio se regenera limpio.

3. Servicios de escritorio remoto por sesión (RDSH, *Remote Desktop Session Host*). Un único servidor con un único sistema operativo atiende **muchas sesiones simultáneas**, cada una con su escritorio o incluso con una sola aplicación publicada (*seamless*). Es el modelo más eficiente en recursos por usuario, pero el menos aislado: un usuario que consume memoria en exceso degrada a los demás, y no puede instalarse software por usuario [MS-RDS].

4. Escritorio como servicio (DaaS, *Desktop as a Service*). VDI o RDSH consumidos como **servicio en la nube** de un proveedor, que asume la infraestructura. Traslada el problema de capacidad al proveedor y lo convierte en gasto corriente, pero añade dependencia de la conectividad a internet y exige contemplar el tratamiento de datos por un tercero [VDI-VENDORS] [RGPD].

> DATO CLAVE
>
> Distinción clave: **VDI** = una **máquina virtual completa por usuario**, con su propio sistema operativo; **RDSH** = **varias sesiones sobre un mismo sistema operativo** de servidor; **DaaS** = cualquiera de los dos anteriores **consumido como servicio en la nube**. El cliente ligero no ejecuta las aplicaciones: solo transmite entradas y recibe la imagen [MS-RDS] [VDI-VENDORS].

La virtualización del puesto **cambia la naturaleza del soporte remoto**. En un escritorio tradicional el técnico se conecta al equipo físico del usuario; en un entorno virtualizado, el técnico puede conectarse a la máquina virtual **desde el centro de datos** sin depender de la red del usuario, y dispone de acciones que en un PC físico son costosas: reiniciar el escritorio, restaurarlo desde la imagen maestra, moverlo a otro anfitrión o clonarlo para analizar el fallo sin bloquear al usuario.

Aspecto	Escritorio tradicional	Escritorio virtualizado (VDI/RDSH)
Dónde se ejecuta la aplicación	En el equipo del usuario	En el servidor del centro de datos
Qué viaja por la red	Datos de las aplicaciones	**Imagen de pantalla, teclado, ratón, audio y periféricos redirigidos**
Dependencia de la red	Trabaja sin red (en local)	**Sin red no hay puesto**
Parcheo	Equipo a equipo	Sobre la **imagen maestra**
Recuperación ante fallo del puesto	Reparar o sustituir el equipo	Reasignar otra máquina virtual en minutos
Fuga de datos	Datos en el disco local	Los datos **no salen** del centro de datos
Soporte remoto	Conexión al equipo del usuario	Conexión a la máquina virtual, o intervención directa desde la consola de la plataforma

RELACIÓN CON OTROS TEMAS

La **virtualización de sistemas y de puestos de usuario** como tecnología —hipervisores, tipos de virtualización, contenedores— corresponde al **Tema 28**; los **paradigmas de computación distribuida y los servicios en la nube** (IaaS, PaaS, SaaS, nubes públicas/privadas/híbridas), al **Tema 31**. Este tema toma la virtualización del puesto únicamente como **escenario de soporte**.

EJEMPLO DE APLICACIÓN EN EL AYTO

Un parque municipal de decenas de miles de puestos rara vez es homogéneo: conviven equipos tradicionales en oficinas, escritorios virtualizados para perfiles con aplicaciones muy estandarizadas (atención en mostrador, tramitación) y portátiles con VPN para teletrabajo. El CAU debe saber, **antes de conectarse**, ante qué modelo está: la misma incidencia («la aplicación de expedientes va lenta») se diagnostica de forma distinta si el proceso corre en el equipo del usuario o en un servidor compartido por doscientas sesiones más.

1.1.2. Componentes hardware y software del puesto de usuario

El técnico de soporte necesita un **modelo mental de los componentes** del puesto, porque cada uno genera una familia distinta de incidencias y admite un tipo distinto de intervención remota.

Componentes hardware relevantes para el soporte:

- **Unidad central (CPU) y memoria (RAM)**: determinan el rendimiento percibido. Una queja de lentitud exige mirar consumo de CPU, memoria y paginación antes de concluir nada.
- **Almacenamiento** (SSD/NVMe o disco mecánico): su llenado o su degradación (sectores defectuosos, SMART en alerta) explica una parte notable de las incidencias de rendimiento y de arranque.
- **Tarjeta de red** con soporte de **PXE** (arranque por red para aprovisionar) y de **Wake-on-LAN** (encendido remoto mediante paquete mágico) [UEFI] [RFC862].
- **Módulo TPM 2.0**: almacena claves y permite el cifrado del disco y el arranque medido; su ausencia o su reinicio provoca incidencias de recuperación de cifrado [TPM20].
- **Controlador de gestión fuera de banda** (BMC en servidores; tecnologías de gestión integradas en placas empresariales de sobremesa): permite actuar con el equipo apagado o con el sistema operativo caído (§1.3.1) [IPMI2] [DSP0266].
- **Periféricos**: monitor, teclado, ratón, impresora, escáner, lector de tarjeta criptográfica y lector de código de barras. Son la causa más frecuente de incidencias «físicas» y, precisamente por serlo, las que peor se resuelven en remoto: nadie puede enchufar un cable a distancia.

> RELACIÓN CON OTROS TEMAS
>
> La **arquitectura de ordenadores y los componentes internos de los equipos microinformáticos** se estudian en el **Tema 11**; los **periféricos, elementos de impresión, almacenamiento, visualización y digitalización**, en el **Tema 12**. Aquí solo se consideran en cuanto origen de incidencias y objeto de intervención remota.

Componentes software relevantes para el soporte:

Capa	Elementos	Incidencias típicas
Firmware	UEFI/BIOS, *Secure Boot*, contraseña de firmware	No arranca, arranque desde dispositivo incorrecto, incompatibilidad tras actualización
Sistema operativo	Núcleo, controladores, servicios, actualizaciones	Pantallas de error, servicios detenidos, actualizaciones fallidas
Configuración y directivas	Directivas de grupo, líneas base de seguridad, restricciones	«Antes podía y ahora no»: un cambio de directiva es una causa frecuente y poco visible
Seguridad	Antivirus/EDR, cifrado de disco, cortafuegos local, control de dispositivos	Bloqueos de aplicaciones legítimas, falsos positivos, recuperación de clave de cifrado
Identidad	Cuenta de dominio, pertenencia a grupos, certificado personal, segundo factor	Bloqueo de cuenta, contraseña caducada, certificado expirado, permisos insuficientes
Conectividad	Configuración de red, cliente VPN, proxy, resolución de nombres	Sin acceso a un recurso concreto pero sí a otros: casi siempre nombres, proxy o permisos
Aplicaciones	Ofimática, navegador, aplicaciones corporativas, complementos de firma	Errores de versión, complementos deshabilitados, incompatibilidad de navegador
Agentes de gestión	Agente de inventario, agente de despliegue, **agente de asistencia remota**	Si el agente no comunica, **el puesto se vuelve invisible y no gestionable**: es una incidencia de soporte en sí misma

DATO CLAVE

El **agente de gestión** instalado en el puesto es el elemento que hace posible el inventario, el despliegue de software, el parcheo y la asistencia **desatendida**. Un equipo cuyo agente no comunica sigue funcionando para el usuario, pero para la organización está **fuera de control**: no se parchea, no se inventaría y no admite asistencia remota sin intervención del usuario [MS-INTUNE] [UEM].

EJEMPLO DE APLICACIÓN EN EL AYTO

En el caso de referencia, la tramitadora no puede firmar el expediente. Recorriendo las capas: ¿está el **lector de tarjeta** conectado y reconocido (hardware/periférico)? ¿Está instalado y activo el **middleware criptográfico** (aplicación)? ¿Ha **caducado el certificado** o está revocado (identidad)? ¿El **navegador** ha deshabilitado el complemento tras una actualización (aplicaciones)? ¿Una **directiva** nueva bloquea el componente (configuración)? ¿Falla la conexión con el servicio de validación (conectividad)? Cinco de esas seis hipótesis se comprueban **en remoto en pocos minutos**; solo la primera puede exigir presencia física o la colaboración de la usuaria.

EJERCICIO RESUELTO

Enunciado: tres usuarios de una misma planta informan de que «internet va lento» a la misma hora. Un cuarto usuario de otra sede no tiene problemas. ¿Por dónde empezar el diagnóstico y qué capa hay que descartar primero? **Solución**: la coincidencia de **varios usuarios**, en el **mismo emplazamiento** y a la **misma hora**, desplaza la hipótesis desde el puesto individual hacia una **capa compartida**: red de la planta, conmutador, enlace de la sede o servicio corporativo consumido por todos ellos. Empezar por revisar el puesto de cada usuario sería el error clásico: se invertiría el tiempo en la capa menos probable. El orden correcto es (1) confirmar el alcance real preguntando si afecta a todos los servicios o solo a algunos, (2) comprobar el estado del enlace y de los equipos de red de la sede mediante la monitorización, (3) verificar si hay una incidencia mayor ya abierta que englobe estas tres, y solo entonces (4) bajar al puesto individual. Además, tres llamadas por la misma causa deben **agruparse bajo una única incidencia** con varios usuarios afectados, lo que además eleva su **impacto** y, por tanto, su prioridad (§2.3.1).

1.2. Fundamentos del control remoto

El **control remoto de puesto de usuario** es la capacidad de un técnico de **ver y manejar** un equipo situado en otro lugar como si estuviera físicamente delante de él: recibe la imagen de la pantalla y envía las pulsaciones de teclado y los movimientos del ratón. Es la herramienta que más ha transformado la productividad del soporte, porque suprime el desplazamiento —el coste dominante del soporte presencial— y permite que un técnico atienda decenas de puestos repartidos por toda la ciudad en una jornada.

Conviene separar tres conceptos que el lenguaje coloquial confunde:

Concepto	Qué es	Ejemplo
Control remoto (asistencia remota)	Tomar el escritorio de un puesto para diagnosticar o actuar sobre él	Ver por qué falla la firma en el equipo de la usuaria
Acceso remoto	Conectarse a los recursos de la organización desde fuera, para **trabajar**	Teletrabajo mediante VPN o escritorio publicado
Administración o gestión remota	Ejecutar tareas de administración sobre sistemas sin usar su escritorio	Instalar un parche por línea de órdenes en cien equipos

DATO CLAVE

Control remoto ≠ acceso remoto ≠ gestión remota. El **control remoto** sirve al **soporte** (ver y manejar el escritorio ajeno); el **acceso remoto** sirve al **usuario** (trabajar desde fuera); la **gestión remota** sirve al **administrador** (ejecutar tareas, normalmente sin interfaz gráfica y a escala). Los tres pueden compartir protocolos, pero responden a finalidades distintas y exigen autorizaciones distintas.

RELACIÓN CON OTROS TEMAS

El **acceso remoto seguro y las VPN** se estudian en el **Tema 36** (seguridad y protección en redes de comunicaciones, seguridad perimetral y seguridad en el puesto de usuario). Este tema se centra en el **control remoto con finalidad de soporte**, aunque comparta con aquel los mecanismos de cifrado y autenticación.

Una segunda distinción, todavía más importante en el sector público, es la que separa la asistencia **atendida** de la **desatendida**:

- **Asistencia atendida** (*attended*): el usuario está presente, **solicita** la asistencia y **consiente** explícitamente la sesión, normalmente comunicando un código de un solo uso o pulsando «Permitir». Es el modelo por defecto para el soporte al puesto y el más respetuoso con la intimidad del empleado.
- **Asistencia desatendida** (*unattended*): un agente instalado permanentemente permite conectarse **sin que haya nadie delante**, típicamente para mantenimiento nocturno, equipos en salas técnicas o quioscos. Es imprescindible en la operación, pero exige controles reforzados: autorización nominal, registro de toda la sesión y justificación documentada de por qué no se pide consentimiento.

DATO CLAVE

La asistencia **atendida** exige **consentimiento explícito del usuario en cada sesión** y muestra un **indicador visible** mientras dura; la **desatendida** no lo exige, y por eso debe compensarse con **autorización previa, mínimo privilegio, registro completo y auditoría**. En un sistema sujeto al ENS, toda sesión de asistencia —atendida o no— debe quedar **registrada y ser atribuible a una persona identificada** [ENS] [RGPD].

Además, toda herramienta de control remoto distingue **modos de operación** con niveles de intrusión decrecientes, que deben elegirse aplicando el principio de mínimo privilegio (§3.1.1):

1. **Solo visualización** (*view only*): el técnico ve la pantalla pero no puede actuar. Suficiente para diagnosticar y para formar al usuario, y el más respetuoso.
2. **Control compartido**: ambos manejan el mismo escritorio; el usuario ve todo lo que hace el técnico y puede interrumpir. Es el modo estándar de la asistencia atendida.
3. **Control exclusivo**: el técnico bloquea la entrada del usuario y, en algunas herramientas, oscurece su pantalla. Útil cuando se manipula información que el usuario no debe ver, pero opaco para él.
4. **Sesión independiente**: el técnico abre **su propia sesión** en el equipo, sin ver ni interferir con la del usuario. Es lo habitual en administración de servidores y en RDP.
5. **Funciones auxiliares**: transferencia de ficheros, chat, ejecución de órdenes, reinicio con reconexión automática, inventario y captura de registros. Cada una de ellas amplía la superficie de riesgo y debe poder habilitarse o deshabilitarse por perfil.

1.2.1. Arquitecturas cliente-servidor y punto a punto

Toda herramienta de control remoto resuelve el mismo problema básico: **poner en contacto dos extremos** —el equipo del usuario y el del técnico— que casi nunca están en la misma red y que suelen estar separados por cortafuegos y por traducción de direcciones (NAT). Existen tres arquitecturas, y conviene distinguirlas.

1. Conexión directa cliente-servidor. El puesto del usuario ejecuta un **servidor** de control remoto que escucha en un puerto (por ejemplo, TCP 5900 para VNC o 3389 para RDP), y el técnico ejecuta un **cliente** que se conecta a su dirección IP. Es el modelo más simple y el más eficiente —no hay intermediarios—, pero exige:

- **visibilidad de red** entre ambos extremos (misma red corporativa o VPN);
- **puertos abiertos entrantes** en el cortafuegos hacia el puesto;
- **conocer la dirección** del puesto, que en redes con direccionamiento dinámico cambia.

Fuera de la red corporativa, este modelo es inviable e inseguro: exponer a internet un puerto de escritorio remoto es una de las causas más habituales de compromiso de sistemas.

DATO CLAVE

Nótese una **inversión terminológica**: en control remoto, el **servidor** es el **equipo que es controlado** (el del usuario, que «sirve» su pantalla) y el **cliente** o *visor* es el del **técnico**. En el sistema X Window ocurre algo análogo y aún más contraintuitivo: el **servidor X** se ejecuta en la máquina **donde está la pantalla del usuario**, y las aplicaciones remotas son los **clientes** [RFC6143] [X11].

2. Conexión mediada por un servidor de intermediación (*broker*, *rendezvous* o servidor de sesión). Es el modelo de las herramientas modernas de asistencia. Ninguno de los dos extremos escucha: **ambos abren una conexión saliente** hacia un servidor de mediación, normalmente por HTTPS en el puerto 443, y este los empareja mediante un identificador de sesión.

Sus ventajas explican su dominio:

- **Atraviesa NAT y cortafuegos sin abrir puertos entrantes**, porque las conexiones salientes hacia el 443 suelen estar permitidas.
- Funciona igual dentro que fuera de la red corporativa: da soporte a un teletrabajador con la misma facilidad que a un puesto de oficina.
- Centraliza la **autenticación, la autorización y el registro** de todas las sesiones en un punto.

Su contrapartida es la **dependencia de la infraestructura de mediación** y, si esa infraestructura es de un tercero en la nube, la necesidad de tratarla como **encargado del tratamiento** y de valorar el riesgo de que el tráfico de sesiones de la organización pase por él [RGPD] [ENS]. Por eso muchas Administraciones despliegan el servidor de mediación **en sus propias instalaciones**.

3. Conexión punto a punto (*peer to peer*) tras la mediación. Es un refinamiento del modelo anterior: el servidor de mediación se usa solo para **presentar** a los dos extremos e intercambiar los datos de conexión; a partir de ahí, ambos intentan establecer un **canal directo** entre sí mediante técnicas de perforación de NAT. Si lo consiguen, el rendimiento mejora y el servidor deja de ver el tráfico; si no, la sesión cae en **retransmisión** (*relay*) y todo el tráfico pasa por el intermediario.

Arquitectura	Requiere puertos entrantes	Funciona fuera de la red	Ancho de banda del intermediario	Uso típico
Directa cliente-servidor	**Sí**	No (salvo VPN)	Ninguno	Red interna, administración de servidores
Mediada con retransmisión	No	**Sí**	Alto (todo el tráfico)	Asistencia a teletrabajo y sedes remotas
Mediada con conexión punto a punto	No	**Sí**	Bajo (solo la señalización)	Modelo dominante en herramientas comerciales

EJEMPLO DE APLICACIÓN EN EL AYTO

Un puesto de una Oficina de Atención a la Ciudadanía está en la red corporativa: el CAU puede llegar a él por **conexión directa** a través de la red municipal, con la dirección obtenida del inventario. Un empleado en teletrabajo con un portátil corporativo, en cambio, se atiende con **conexión mediada**: su equipo abre una sesión saliente hacia el servidor de asistencia del Ayuntamiento y el técnico se empareja con él mediante un código. Si el portátil está conectado por VPN, ambos modelos son posibles, y suele preferirse el mediado por ser independiente del estado del túnel —precisamente cuando la incidencia es *que la VPN no funciona*, el modelo directo es inútil.

EJERCICIO RESUELTO

Enunciado: una empleada teletrabaja desde su domicilio con un portátil corporativo. Informa de que **no le levanta la VPN**. El CAU necesita ver su equipo. ¿Qué arquitectura de conexión puede usar y por qué queda descartada la otra? **Solución**: queda descartada la **conexión directa** por dos razones acumuladas: el portátil está tras el NAT del rúter doméstico, sin puertos entrantes publicados y con una dirección pública compartida y cambiante; y, aunque lo estuviera, la vía natural para alcanzarlo desde la red corporativa —la VPN— es justamente lo que está averiado. La opción viable es la **conexión mediada**: el agente de asistencia del portátil abre una conexión **saliente** por HTTPS hacia el servidor de mediación de la organización, la empleada facilita el código de sesión y el técnico se empareja con ella. La lección general que conviene retener: **la herramienta de soporte no debe depender del servicio que puede estar averiado**; si la asistencia remota solo funcionara sobre la VPN, sería inútil precisamente en la incidencia más frecuente del teletrabajo.

1.2.2. Mecanismos de autenticación, autorización y sesión

Una sesión de control remoto entrega a un tercero **el control completo de un puesto** y, con él, el acceso a todo lo que ese puesto ve: correo, expedientes, datos personales de ciudadanos y credenciales en uso. Es, por tanto, una de las operaciones más sensibles de un sistema de información, y se gobierna con el modelo clásico **AAA**: **autenticación** (quién eres), **autorización** (qué puedes hacer) y **contabilidad o registro** (qué has hecho) [RFC2865].

Autenticación. Debe responder a dos preguntas distintas, y las herramientas maduras responden a las dos:

- **¿Quién es el técnico?** Nunca una cuenta genérica compartida por el equipo de soporte. La identidad debe ser **nominal** y provenir del directorio corporativo (LDAP/Active Directory, con Kerberos o con protocolos de federación), reforzada con **segundo factor** cuando el privilegio es alto [RFC4511] [RFC4120].
- **¿Quién es el equipo remoto?** El cliente debe verificar la identidad del extremo al que se conecta —mediante certificado X.509 o mediante la huella de la clave del servidor en SSH—, para evitar que un atacante suplante al puesto e interponga su propio extremo (ataque de intermediario) [RFC5280] [RFC4253].

> DATO CLAVE
>
> Autenticar **al técnico** no basta: hay que autenticar también **al equipo remoto**. Si el visor acepta cualquier certificado o cualquier clave de servidor sin verificación, un atacante puede situarse en medio y capturar la sesión completa. La primera conexión SSH pregunta por la **huella** de la clave del servidor por esta razón, y aceptarla a ciegas anula la garantía [RFC4253].

Los mecanismos concretos de autenticación más habituales, ordenados de menor a mayor robustez, son:

1. **Contraseña de acceso propia de la herramienta**: la clásica «contraseña de VNC». Es débil (compartida, estática, a veces limitada en longitud) y desaconsejada como único mecanismo.
2. **Credenciales del sistema operativo o del dominio**: la sesión se autoriza contra el directorio corporativo, con la política de contraseñas de la organización.
3. **Tique de autenticación de red** (Kerberos): sin envío de contraseña, con tiques de validez limitada; es el modelo de RDP con autenticación a nivel de red [RFC4120].
4. **Clave pública** (SSH) o **certificado de cliente** (TLS): sin secreto compartido reutilizable, resistente a la captura [RFC4252] [RFC5280].
5. **Código de sesión de un solo uso** generado en el puesto del usuario y comunicado verbalmente al técnico: no autentica al técnico, pero **materializa el consentimiento** y limita la sesión a esa ocasión concreta.
6. **Autenticación multifactor** sobre cualquiera de las anteriores para los perfiles de mayor privilegio.

Autorización. Responde a *qué puede hacer ese técnico y sobre qué equipos*. Se articula mediante:

- **Control de acceso basado en roles (RBAC)**: perfiles de soporte (primer nivel, segundo nivel, administrador) con capacidades distintas —ver, controlar, transferir ficheros, ejecutar órdenes, acceder desatendido—.
- **Ámbito o alcance**: cada perfil solo alcanza los grupos de equipos que le corresponden (por distrito, por área, por tipo de puesto). Un técnico de primer nivel no debería poder tomar el puesto de un cargo directivo ni un servidor.
- **Segregación de funciones**: quien administra la herramienta de asistencia no debería ser quien audita sus registros [ENS] [ISO27001].
- **Elevación temporal de privilegios** (*just in time*): el permiso se concede para una ventana concreta y caduca solo, en lugar de ser permanente.

Gestión de la sesión. Una vez autenticado y autorizado, el control de la sesión aporta las últimas garantías:

Control	Qué aporta
Consentimiento explícito en asistencia atendida	Base del respeto a la intimidad del empleado y prueba de que la sesión fue solicitada
Indicador visible permanente (banner, borde de color, icono)	El usuario sabe en todo momento que está siendo observado
Corte unilateral por el usuario	El usuario puede terminar la sesión sin depender del técnico
Expiración por inactividad y duración máxima	Evita sesiones olvidadas abiertas indefinidamente
Bloqueo automático del puesto al desconectar	Impide que la sesión quede abierta y utilizable por quien pase por delante
Registro y, en su caso, grabación de la sesión	Trazabilidad exigible por el ENS (§3.1.2)
Cifrado extremo a extremo del canal	Confidencialidad e integridad de lo transmitido (§1.3.2)

EJEMPLO DE APLICACIÓN EN EL AYTO

En el caso de referencia, la secuencia correcta es: la tramitadora llama al CAU; el técnico **la identifica** (número de empleada, extensión, ubicación) y **registra la incidencia**; le pide que abra la herramienta de asistencia y le facilite el **código de sesión**; el técnico se autentica con **su cuenta nominal** y su segundo factor; la usuaria **acepta** la solicitud y ve un indicador permanente en pantalla; el técnico trabaja en modo **control compartido**, pidiéndole que cierre antes documentos con datos de terceros que no necesita ver; al terminar, la sesión se cierra, el puesto **se bloquea** y queda registrado quién, cuándo, sobre qué equipo, durante cuánto tiempo y en el marco de qué incidencia se actuó.

1.3. Protocolos y tecnologías de control remoto

1.3.1. Protocolos de nivel de aplicación para gestión remota

Los protocolos de control y gestión remota se sitúan en el **nivel de aplicación** del modelo TCP/IP y se apoyan casi siempre en TCP por necesitar entrega fiable y ordenada; algunos añaden UDP para el transporte de imagen y audio, donde la latencia importa más que la fiabilidad absoluta.

RELACIÓN CON OTROS TEMAS

El **modelo TCP/IP y el modelo de referencia OSI**, así como los protocolos de transporte TCP y UDP, se estudian en el **Tema 34**; **HTTP, HTTPS y SSL/TLS**, en el **Tema 35**. Aquí se presuponen y solo se citan los puertos y las características que distinguen a cada protocolo de gestión.

RFB — Remote Framebuffer (VNC). Definido en el **RFC 6143**, es el protocolo abierto por excelencia del control remoto gráfico. Su idea es deliberadamente simple: el servidor —el equipo controlado— envía al cliente el contenido de su **framebuffer**, es decir, **los píxeles de la pantalla**, y el cliente le devuelve **eventos de teclado y de ratón**. De ahí se derivan todas sus propiedades [RFC6143]:

- Es **independiente del sistema operativo, del gestor de ventanas y de las aplicaciones**: todo lo que se ve, se transmite. Existen implementaciones para Windows, Linux, macOS y sistemas embebidos.
- Es **sin estado desde el punto de vista del cliente**: un cliente puede desconectarse y reconectarse y encontrar el escritorio tal como estaba.
- **Comparte por defecto la sesión de consola**: el técnico ve exactamente lo que ve el usuario, lo que lo hace idóneo para asistencia.
- A cambio, es **costoso en ancho de banda** frente a los protocolos que transmiten primitivas gráficas, y por sí mismo **no cifra**: su autenticación clásica es una contraseña con un esquema de desafío-respuesta débil, por lo que en la práctica se **tuneliza sobre SSH o TLS** (§1.3.2).

- Puerto de referencia: **TCP 5900** (más el número de pantalla: 5901 para la pantalla 1, y así sucesivamente).

RDP — Remote Desktop Protocol. Protocolo de Microsoft, documentado públicamente en las especificaciones abiertas [MS-RDPBCGR], usa el puerto **TCP 3389** y también **UDP 3389** para el transporte optimizado de imagen y audio. Su enfoque es el opuesto al de RFB: en lugar de mandar píxeles, envía **primitivas de dibujo y órdenes gráficas** que el cliente reproduce, además de multiplexar **canales virtuales** para funciones auxiliares:

- **Redirección de dispositivos**: impresoras, unidades de disco locales, puertos, tarjetas inteligentes, portapapeles y audio del equipo del técnico se hacen visibles en la sesión remota.
- **Sesiones independientes**: por defecto abre una sesión nueva, distinta de la del usuario, lo que lo hace idóneo para administración pero **no** para asistencia (el usuario no ve lo que hace el técnico). Para asistir hay que usar la función de **observación de sesión** (*shadowing*) o una herramienta de asistencia específica.
- **Cifrado y autenticación integrados**: TLS y autenticación a nivel de red antes de presentar el escritorio, lo que evita consumir recursos con conexiones no autenticadas.
- **Pasarela de escritorio remoto**: encapsula RDP dentro de **HTTPS (443)** para atravesar cortafuegos sin publicar el 3389 [MS-RDS].

> DATO CLAVE
>
> **VNC/RFB transmite píxeles; RDP transmite primitivas gráficas y canales virtuales.** De ahí que RDP consuma menos ancho de banda y permita redirigir impresoras y discos, mientras que VNC es más simple y más portable entre sistemas. **VNC comparte la sesión del usuario** (idóneo para asistencia); **RDP abre por defecto una sesión independiente** (idóneo para administración). Puertos: **5900** y **3389** [RFC6143] [MS-RDPBCGR].

SSH — Secure Shell. Definido en los **RFC 4251 a 4254**, es el estándar de administración remota en sistemas Unix y Linux, y hoy también en equipamiento de red y en Windows. Trabaja en el puerto **TCP 22** y se estructura en tres capas [RFC4251]:

1. **Capa de transporte** (RFC 4253): negocia algoritmos, intercambia claves, **autentica al servidor** y establece un canal cifrado con control de integridad.
2. **Capa de autenticación de usuario** (RFC 4252): contraseña, **clave pública** (el método recomendado) o autenticación basada en el equipo de origen.
3. **Capa de conexión** (RFC 4254): multiplexa **varios canales lógicos** sobre la única conexión cifrada: sesión interactiva, ejecución de una orden concreta, transferencia de ficheros (SFTP), **reenvío de puertos** y reenvío gráfico de X11.

El **reenvío de puertos** merece atención especial porque es la técnica que permite proteger protocolos que nacieron sin cifrado: se abre un puerto local que se encamina cifrado por el túnel SSH hasta el destino. Es el modo canónico de usar VNC con seguridad.

Telnet, en el puerto **TCP 23**, fue el antecesor de SSH y transmite **todo en texto claro, incluidas las credenciales**. Está formalmente desaconsejado y debe estar deshabilitado en cualquier sistema sujeto al ENS; solo pervive en equipamiento antiguo aislado.

WinRM y WS-Management. Microsoft implementa el estándar **WS-Management** de DMTF [DSP0226] bajo el nombre de **WinRM**, base de *PowerShell Remoting*. Permite ejecutar órdenes y sesiones interactivas de consola contra equipos Windows, con autenticación integrada del dominio. Puertos **TCP 5985 (HTTP)** y **5986 (HTTPS)**. Es el equivalente funcional de SSH en el mundo Windows para la **gestión sin interfaz gráfica** [MS-WINRM].

SNMP. Protocolo clásico de **monitorización y gestión** de dispositivos, no de control de escritorio: consulta variables organizadas en una base de información de gestión (MIB) y recibe notificaciones asíncronas. Puertos **UDP 161** (consultas) y **UDP 162** (*traps*). La versión **SNMPv3** es la única que aporta seguridad real (autenticación y cifrado); las versiones 1 y 2c se basan en una «comunidad» en texto claro [RFC3411]. Su relevancia en este tema es doble: **detecta eventos** que originan incidencias (§2.4) y alimenta la monitorización del parque.

NETCONF (RFC 6241), sobre SSH en el puerto **830**, y **Redfish** (DMTF DSP0266), sobre HTTPS y REST, representan la generación moderna de gestión de configuración de dispositivos e infraestructura [RFC6241] [DSP0266]. Ambos, junto con las consolas web de gestión y las API de las plataformas ITSM, se apoyan en la semántica de **HTTP** —métodos, cabeceras y códigos de estado — definida en el RFC 9110 [RFC9110].

Gestión fuera de banda (*out-of-band*). Todos los protocolos anteriores exigen que el equipo esté **encendido y con su sistema operativo funcionando**. Cuando no lo está, la única vía es un **canal independiente** que atiende un controlador dedicado con su propio procesador, su propia red y su propia alimentación: el **BMC** (*Baseboard Management Controller*) en servidores, o las tecnologías de gestión integradas en el chipset de los equipos empresariales de sobremesa. Con ellos se puede **encender, apagar, reiniciar, ver la consola desde el arranque, entrar en el firmware y montar una imagen de instalación remota** aunque el sistema operativo esté caído. El estándar clásico es **IPMI** (puerto **UDP 623**) y el moderno, **Redfish** sobre HTTPS [IPMI2] [DSP0266].

DATO CLAVE

Dentro de banda (*in-band*) = la gestión viaja por el mismo canal y depende del sistema operativo del equipo (RDP, VNC, SSH, WinRM). **Fuera de banda** (*out-of-band*) = viaja por un canal independiente atendido por un controlador dedicado y **funciona con el equipo apagado o con el sistema operativo caído** (IPMI/BMC, Redfish). La gestión fuera de banda es la única que resuelve un «no arranca» sin desplazamiento [IPMI2].

Wake-on-LAN. Complemento imprescindible de la gestión remota: un **paquete mágico** dirigido a la dirección física del equipo, enviado convencionalmente a los puertos **UDP 7 o 9**, hace que la tarjeta de red —que permanece alimentada— **encienda el equipo** [RFC862]. Permite parchear de madrugada un parque de puestos apagados y volver a apagarlos antes de la jornada, sin molestar al usuario ni depender de que este deje el equipo encendido.

Protocolo	Puerto(s)	Naturaleza	Uso principal
RFB (VNC)	TCP 5900+N	Gráfico, píxeles	Asistencia compartiendo la sesión del usuario
RDP	TCP/UDP 3389	Gráfico, primitivas y canales	Escritorio remoto y administración; sesión independiente
SSH	TCP 22	Texto cifrado + túneles	Administración de Unix/Linux y red; protección de otros protocolos
Telnet	TCP 23	Texto **en claro**	**Obsoleto y desaconsejado**
WinRM	TCP 5985/5986	Servicios web (WS-Management)	Administración y automatización en Windows
SNMP	UDP 161/162	Consulta y notificación	Monitorización y detección de eventos
NETCONF	TCP 830 (sobre SSH)	XML sobre SSH	Configuración de dispositivos de red
IPMI	UDP 623	Fuera de banda	Control del equipo apagado o sin sistema operativo
Redfish	TCP 443 (HTTPS)	REST fuera de banda	Sucesor moderno de IPMI
X11 (reenvío)	TCP 6000+N	Gráfico por objetos	Aplicaciones gráficas Unix; hoy siempre sobre SSH
Wake-on-LAN	UDP 7/9	Paquete mágico	Encendido remoto para mantenimiento

EJERCICIO RESUELTO

Enunciado: hay que actualizar el firmware de un equipo que **no arranca** el sistema operativo y está en una sede a veinte kilómetros. ¿Qué tecnología permite hacerlo sin desplazamiento y por qué no sirven RDP, VNC ni SSH? **Solución**: RDP, VNC y SSH son mecanismos **dentro de banda**: sus servidores son procesos del sistema operativo del equipo, de modo que si el sistema operativo no arranca, esos servicios no existen y no hay nada a lo que conectarse. La solución es la **gestión fuera de banda** mediante el controlador de gestión integrado (BMC con **IPMI** en el puerto UDP 623, o **Redfish** sobre HTTPS): ese controlador tiene procesador, memoria, interfaz de red y alimentación propios, independientes del sistema operativo, y ofrece consola remota desde el mismo encendido, control de la alimentación y montaje de imágenes de instalación. Si el equipo estuviera apagado en lugar de averiado, bastaría además con **Wake-on-LAN** para encenderlo. Y si careciera de controlador de gestión —el caso de muchos puestos de gama de consumo—, no habría alternativa remota: la incidencia exigiría **desplazamiento** y debería clasificarse y priorizarse teniendo en cuenta ese coste (§2.3.1).

1.3.2. Canales de comunicación seguros y cifrado

Una sesión de control remoto transporta **la pantalla completa de un puesto de trabajo**, incluidos documentos, correo, datos personales de ciudadanos y, potencialmente, credenciales tecleadas durante la sesión. Es tráfico de máxima sensibilidad, y su protección debe cubrir cuatro propiedades:

Propiedad	Qué evita	Mecanismo
Confidencialidad	Que un tercero lea la pantalla y las pulsaciones	Cifrado simétrico del canal (AES)
Integridad	Que un tercero altere lo transmitido	Códigos de autenticación de mensaje (HMAC) o cifrado autenticado
Autenticidad	Que un tercero suplante a uno de los extremos	Certificados X.509, claves de servidor SSH
No repudio y trazabilidad	Que no pueda saberse quién hizo qué	Registro nominal de sesiones (§3.1.2)

TLS (RFC 9846 para la versión 1.3, que sustituye en 2026 al RFC 8446) es hoy el mecanismo dominante: protege RDP, las consolas web de gestión, las API de las plataformas ITSM y el tráfico de las herramientas de asistencia mediadas. Aporta negociación de algoritmos, autenticación del servidor mediante **certificado X.509** validado contra una autoridad de confianza, intercambio de claves con **confidencialidad hacia adelante** (*forward secrecy*) —de modo que comprometer la

clave privada del servidor no permite descifrar sesiones pasadas grabadas— y cifrado autenticado del canal [RFC9846] [RFC5280].

SSH cumple la misma función en el mundo de la administración de sistemas, con una diferencia importante en el modelo de confianza: en lugar de una autoridad de certificación, se apoya normalmente en la **huella de la clave del servidor**, que el cliente memoriza en la primera conexión y verifica en las siguientes. Es el modelo de «confianza en el primer uso», que solo es seguro si esa primera conexión se hace en condiciones controladas o si la huella se distribuye por otro medio [RFC4253].

Encapsulado y tunelización. Los protocolos que no cifran —VNC clásico, protocolos de gestión antiguos— no deben usarse desnudos. Las tres soluciones habituales son:

1. **Túnel SSH** con reenvío de puertos: el tráfico de VNC viaja dentro de la conexión SSH cifrada; el servidor VNC se configura para escuchar **solo en la interfaz local**, de modo que sea inalcanzable directamente [RFC4254].
2. **Túnel TLS** o pasarela: un extremo de terminación TLS recibe la conexión y la reenvía en claro solo dentro de un segmento controlado. Es el modelo de las pasarelas de escritorio remoto que publican RDP sobre HTTPS [MS-RDS].
3. **Red privada virtual (VPN)**: el puesto remoto se incorpora lógicamente a la red corporativa y todo el tráfico —incluido el de gestión— viaja cifrado dentro del túnel.

DATO CLAVE

VNC clásico no cifra: su contraseña se protege con un esquema de desafío-respuesta débil y el resto del tráfico —incluida la pantalla— viaja en claro. El uso correcto es **tunelizarlo sobre SSH o TLS** y hacer que el servidor VNC escuche únicamente en la interfaz local. Un servidor VNC expuesto directamente a internet es un fallo grave de seguridad [RFC6143] [RFC4254].

RELACIÓN CON OTROS TEMAS

Los **conceptos de seguridad de los sistemas de información** —seguridad física y lógica, amenazas y vulnerabilidades, técnicas criptográficas, protocolos seguros y firma digital— corresponden al **Tema 32**; la **seguridad perimetral, el acceso remoto seguro y las VPN**, al **Tema 36**; **HTTPS y SSL/TLS** en cuanto protocolos de internet, al **Tema 35**. Este epígrafe se limita a su aplicación al canal de asistencia.

Buenas prácticas de fortificación del canal de asistencia, exigibles en un sistema sujeto al ENS [ENS] [CCN-STIC]:

- **No exponer nunca a internet** los puertos 3389, 5900 o 22 de los puestos; publicarlos solo a través de pasarela con autenticación previa o de VPN.

- **Deshabilitar protocolos y algoritmos obsoletos** (Telnet, versiones antiguas de TLS y de SSH, algoritmos de cifrado o resumen deprecados).
- **Restringir el origen** de las conexiones de gestión a los rangos de red de los equipos de soporte (segmento de administración separado).
- **Segmentar la red de gestión** respecto de la red de usuarios, de modo que un puesto comprometido no pueda alcanzar los interfaces de administración.
- **Usar equipos de administración dedicados** y fortificados para las tareas de mayor privilegio, en lugar del puesto ofimático habitual del técnico.
- **Limitar y auditar la transferencia de ficheros y el portapapeles** dentro de la sesión: son la vía más directa de exfiltración de información durante una asistencia.

1.3.3. Herramientas de asistencia remota en sistemas operativos

Todos los sistemas operativos de puesto incorporan, de serie, mecanismos de asistencia remota; conocerlos evita depender de productos de terceros para las tareas más habituales.

Entornos Windows.

Herramienta	Naturaleza	Uso característico
Asistencia rápida (*Quick Assist*)	Asistencia **atendida** con código de sesión y consentimiento; conexión mediada por servicio en la nube	Soporte al usuario final, dentro y fuera de la red corporativa [MS-QUICKASSIST]
Asistencia remota de Windows (`msra`)	Asistencia atendida clásica mediante fichero de invitación o *Easy Connect*; en desuso	Entornos heredados sin conectividad a servicios externos
Conexión a Escritorio remoto (`mstsc` , RDP)	**Sesión independiente**, no compartida	Administración de servidores y acceso a escritorios publicados [MS-RDPBCGR]
Observación de sesión (*shadowing*) en Servicios de Escritorio Remoto	Ver o controlar la sesión **existente** de un usuario, con o sin consentimiento según configuración	Soporte en entornos RDSH y VDI [MS-RDS]
PowerShell Remoting / WinRM	Ejecución de órdenes y sesiones de consola, sin interfaz gráfica	Diagnóstico y corrección masiva, automatización [MS-WINRM]
Consolas de administración remota (visor de eventos, administración de equipos, RSAT)	Conexión a un equipo remoto desde una consola local	Consultar registros o servicios **sin molestar al usuario**
Directivas de grupo	Configuración centralizada, incluida la de escritorio remoto y los grupos autorizados	Habilitar o restringir quién puede tomar control [MS-GPO]

Un matiz importante: **no toda intervención remota exige tomar el escritorio**. Consultar el visor de eventos remoto, comprobar servicios o ejecutar una orden por WinRM son intervenciones **menos intrusivas** que un control remoto completo, y el principio de mínimo privilegio obliga a preferirlas cuando bastan.

Entornos Unix y Linux.

- **SSH** (OpenSSH) es la herramienta universal: sesión de terminal, ejecución de órdenes, transferencia de ficheros con SCP y SFTP, túneles y reenvío de X11 [OPENSSH].

- **Reenvío de X11** (`ssh -X`): ejecuta una aplicación gráfica en el equipo remoto mostrando su ventana en el equipo local, sin transmitir el escritorio entero. Recuérdese el modelo invertido: el **servidor X** está en la máquina del usuario [X11].
- **VNC** en sus distintas implementaciones: `x11vnc` para **compartir la sesión física existente** —el caso de asistencia—, o servidores VNC que crean **sesiones virtuales nuevas** e independientes, que no sirven para asistir porque el usuario no las ve [TIGERVNC].
- **xrdp** para atender clientes RDP contra un escritorio Linux, y **X2Go** para acceso gráfico eficiente sobre SSH [XRDP].
- **SPICE** para el acceso a escritorios de máquinas virtuales, con buena gestión de audio, vídeo y redirección de USB [SPICE].
- **Multiplexores de terminal** (`screen`, `tmux`): permiten que una sesión de trabajo **sobreviva a la caída de la conexión** y sea retomada, e incluso compartida entre dos técnicos. Es la forma más simple de «asistencia» en línea de órdenes.

Entornos macOS. *Compartir pantalla* se basa en VNC/RFB con extensiones propias de autenticación, y **Apple Remote Desktop** añade gestión de parque: inventario, despliegue de paquetes, ejecución de órdenes y observación simultánea de varias pantallas [APPLE-ARD].

Herramientas multiplataforma de terceros. Productos como los citados en [ITSM-TOOLS] y las suites comerciales de asistencia aportan conexión mediada lista para usar, catálogo de equipos, grabación de sesiones, integración con la herramienta de tiques y soporte a dispositivos móviles. Su elección en el sector público debe valorar el **lugar de tratamiento de los datos**, la posibilidad de **desplegar el servidor de mediación en las instalaciones propias** y la conformidad con el ENS [ENS] [RGPD].

> **DATO CLAVE**
>
> Para **asistir** a un usuario hay que **compartir su sesión** (VNC sobre la consola física, *shadowing* de RDS, Asistencia rápida). Si la herramienta abre una **sesión nueva** —RDP estándar, servidor VNC virtual—, el técnico verá un escritorio distinto del que el usuario tiene delante y **no reproducirá su problema**. Es el error más común de un técnico novel [MS-RDS] [TIGERVNC].

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
>
> Para el problema de firma del caso de referencia, el técnico **necesita** compartir la sesión de la tramitadora: el lector de tarjeta está conectado a **su** equipo y el certificado está en **su** sesión, con **su** configuración de navegador. Conectarse por RDP abriendo una sesión propia no reproduciría el fallo —de hecho, expulsaría a la usuaria de su sesión en una edición de escritorio— y además, en muchas configuraciones, la tarjeta criptográfica no estaría disponible. El modo correcto es la asistencia atendida en **control compartido** sobre la sesión existente.

1.3.4. Soluciones centralizadas de gestión de puestos de trabajo

Atender puestos de uno en uno no escala. Una organización con decenas de miles de equipos necesita **gestionar el parque como un conjunto**, y ahí entran las plataformas de gestión centralizada —conocidas como gestión de clientes, gestión de dispositivos móviles (MDM) o, en su versión moderna e integrada, **gestión unificada de puntos finales (UEM)**—.

Sus funciones se agrupan en seis bloques:

1. Inventario y descubrimiento. Un agente instalado en cada puesto —o un descubrimiento sin agente por red— recopila y actualiza el inventario de hardware y software: modelo, número de serie, procesador, memoria, disco, versión del sistema operativo, aplicaciones instaladas, parches aplicados y periféricos. Este inventario es la base de la **CMDB** (base de datos de gestión de la configuración), que da soporte a la gestión de incidencias identificando el **elemento de configuración** afectado (§2.2.2) [ITIL4] [UEM].

2. Despliegue de sistemas operativos y de software. Instalación desatendida a partir de una **imagen maestra** o de un aprovisionamiento moderno basado en el registro previo del equipo en el fabricante, arranque por red **PXE**, catálogo de aplicaciones autoservicio y desinstalación remota [UEFI] [MS-INTUNE].

3. Gestión de la configuración y del cumplimiento. Aplicación de **líneas base de seguridad**, directivas de grupo o perfiles de configuración, y evaluación continua del **cumplimiento**: qué equipos se desvían de la línea base y remediación automática de la desviación [MS-GPO] [ANSIBLE].

4. Gestión de parches y actualizaciones. Distribución escalonada por anillos (piloto → grupo reducido → parque completo), ventanas de mantenimiento, verificación de instalación y **cuadro de mando de cobertura de parcheo**. Es la medida técnica que más incidencias evita y, a la vez, la que más incidencias provoca cuando un parche sale defectuoso: de ahí el despliegue por anillos [WSUS].

5. Seguridad del punto final. Despliegue y supervisión del antivirus/EDR, cifrado del disco con **custodia de las claves de recuperación**, control de dispositivos extraíbles y **borrado remoto** de equipos perdidos o robados [UEM] [TPM20].

6. Soporte y asistencia integrados. Acciones remotas sobre uno o muchos equipos (reiniciar, reinstalar una aplicación, forzar sincronización, recoger registros de diagnóstico) y lanzamiento de la sesión de control remoto **desde la propia ficha del equipo o desde el tique de la incidencia**.

DATO CLAVE

La gestión centralizada de puestos convierte el soporte **reactivo** (esperar la llamada del usuario) en **proactivo** (detectar el disco lleno, el parche que falta o el antivirus desactualizado **antes** de que provoquen una incidencia). Esa es su principal aportación al indicador de calidad del servicio: reduce el número de incidencias, no solo el tiempo de resolución [ITIL4] [COBIT2019].

Modelos de arquitectura. Las plataformas tradicionales se despliegan **en las instalaciones propias**, con servidores de distribución en cada sede para no saturar los enlaces; las modernas son **servicios en la nube** que gestionan el equipo dondequiera que esté, sin necesidad de VPN, lo que resulta decisivo para el teletrabajo. Los modelos **híbridos** —coexistencia de ambas— son hoy lo más habitual en Administraciones con parques heredados [MS-INTUNE] [UEM].

Gestión de configuración sin agente. Herramientas como Ansible operan **sin instalar agente**, conectándose por SSH (Linux) o WinRM (Windows) y aplicando descripciones declarativas del estado deseado con **idempotencia**: ejecutar dos veces la misma tarea deja el sistema en el mismo estado, sin efectos acumulativos. Es el modelo dominante en servidores y creciente en puestos Linux [ANSIBLE].

RELACIÓN CON OTROS TEMAS

La **administración de redes de área local** —gestión de usuarios y de dispositivos, monitorización y control de tráfico— corresponde al **Tema 30**, con el que este epígrafe limita directamente: allí la unidad de gestión es la red; aquí, el puesto. La **administración del sistema operativo y del software de base**, incluida la actualización y el mantenimiento, es objeto del **Tema 27**.

EJEMPLO DE APLICACIÓN EN EL AYTO

Si el fallo de firma de la tramitadora resultara deberse a una **versión desactualizada del middleware criptográfico**, la plataforma de gestión centralizada permite responder a tres preguntas en minutos: **cuántos** puestos del parque tienen esa misma versión, **qué distritos y áreas** concentran el problema y **con qué despliegue** se corrige. Ahí la incidencia individual deja de tratarse una a una y se convierte en un **problema** con solución masiva (§2.4.2): en lugar de resolver ciento cuarenta incidencias idénticas, se despliega una actualización y se cierran todas.

EJERCICIO RESUELTO

Enunciado: la organización quiere reducir el número de desplazamientos del equipo de soporte a las sedes. Enumere tres capacidades técnicas que hagan posible resolver en remoto incidencias que hoy exigen presencia, e indique qué tipo de incidencia seguirá exigiéndola. **Solución**: (1) **Gestión fuera de banda** (IPMI/BMC o equivalente en el puesto) más **Wake-on-LAN**, que permiten encender el equipo, entrar en el firmware y ver la consola desde el arranque, cubriendo los casos de «no arranca» y de reinstalación del sistema operativo. (2) **Plataforma de gestión centralizada con agente**, que permite reinstalar aplicaciones, aplicar parches, recoger registros de diagnóstico y reaplicar la configuración sin intervención del usuario. (3) **Asistencia remota mediada por servidor**, que alcanza el puesto esté donde esté —oficina, sede remota o domicilio— sin depender de la VPN. Seguirán exigiendo presencia física las incidencias de **hardware y periféricos**: sustitución de un equipo, de un disco, de un monitor o de un lector de tarjetas, reconexión de cables y cualquier avería que impida la alimentación o la conectividad del equipo. Ese resto irreducible es el que justifica mantener un **soporte de campo** dimensionado, y sus tiempos deben pactarse por separado en el acuerdo de nivel de servicio (§2.3.4), porque incluyen desplazamiento.

2. Gestión de la resolución de incidencias en los servicios TI

2.1. Marcos de referencia para la gestión de servicios TI

La **gestión de servicios TI** (ITSM, *IT Service Management*) es la disciplina que organiza las actividades de una organización de tecnología para **entregar valor a sus usuarios en forma de servicios**, y no en forma de tecnología. El cambio de perspectiva que introduce es sencillo de enunciar y difícil de practicar: al usuario no le interesa el servidor ni el protocolo, sino **poder tramitar el expediente**. Toda la gestión de incidencias se deriva de ahí.

Los tres marcos de referencia que hay que conocer, y que a menudo se confunden, son:

Marco	Naturaleza	Qué aporta	¿Certifica?
ITIL 4	**Marco de buenas prácticas**, no normativo	Vocabulario común, prácticas, cadena de valor y principios guía	Certifica a **personas**, no a organizaciones [ITIL4]
ISO/IEC 20000-1:2018	**Norma certificable** de requisitos	Requisitos auditables de un **sistema de gestión del servicio (SGS)**	Certifica a **organizaciones** [ISO20000]
COBIT 2019	Marco de **gobierno** de la información y la tecnología	Alineación con los objetivos de la organización, objetivos de gobierno y de gestión, métricas	Certifica a personas [COBIT2019]

DATO CLAVE

ITIL no se certifica como organización: se certifica a las personas. La certificación de una organización en gestión de servicios se obtiene con **ISO/IEC 20000-1**. ITIL propone *buenas prácticas* adaptables; ISO/IEC 20000-1 impone *requisitos* auditables; **COBIT** se sitúa por encima, en el plano del **gobierno**, respondiendo a qué debe hacer la tecnología para cumplir los objetivos de la organización [ITIL4] [ISO20000] [COBIT2019].

La relación entre ellos es de complemento, no de competencia: una organización puede **gobernar** con COBIT, **operar** con las prácticas de ITIL y **certificarse** con ISO/IEC 20000-1. En el sector público español, además, se superpone el **ENS**, que no es un marco de gestión de servicios sino de **seguridad**, pero que impone requisitos directos sobre la gestión de incidentes y sobre la trazabilidad de las actuaciones (§3.2.1) [ENS].

2.1.1. Principios de ITIL aplicados a la gestión de incidencias

ITIL (*Information Technology Infrastructure Library*) nació en los años ochenta en el Reino Unido como compendio de buenas prácticas para la gestión de servicios de tecnología en la Administración, y ha evolucionado hasta la versión **ITIL 4**, que reorganiza por completo el marco.

El cambio conceptual de ITIL 4. Las versiones anteriores (ITIL v2 y v3/2011) describían **procesos** agrupados en fases del ciclo de vida del servicio (estrategia, diseño, transición, operación y mejora continua), con la gestión de incidencias como proceso de la fase de **operación** y el *Service Desk* como **función**. ITIL 4 sustituye esa estructura por el **Sistema de Valor del Servicio (SVS)** y habla de **prácticas** (34 en total) en lugar de procesos [ITIL4] [ITILV3].

Los elementos de ITIL 4 que conviene retener son cuatro:

1. Los siete principios guía, aplicables a cualquier mejora:

1. **Enfocarse en el valor**: toda actividad debe aportar valor al usuario o a la organización.
2. **Empezar donde se está**: aprovechar lo existente en lugar de partir de cero.
3. **Progresar iterativamente con retroalimentación**: mejoras pequeñas y medidas, no grandes proyectos.
4. **Colaborar y promover la visibilidad**: trabajar con las partes implicadas y hacer visible el trabajo.
5. **Pensar y trabajar holísticamente**: ningún servicio funciona aislado.
6. **Mantenerlo simple y práctico**: eliminar lo que no aporta.
7. **Optimizar y automatizar**: optimizar primero, automatizar después —automatizar un proceso malo lo empeora a escala—.

2. Las cuatro dimensiones que hay que atender simultáneamente en cualquier servicio: **organizaciones y personas**; **información y tecnología**; **socios y proveedores**; y **flujos de valor y procesos**. Un CAU que compra la mejor herramienta pero no forma a sus técnicos ni redefine su flujo de trabajo ha atendido una dimensión de cuatro.

3. La cadena de valor del servicio, con seis actividades interconectadas: **planificar**, **mejorar**, **involucrar** (relación con las partes interesadas), **diseñar y hacer la transición**, **obtener o construir**, y **entregar y dar soporte**. La atención de una incidencia recorre principalmente **involucrar** (recepción y comunicación con el usuario) y **entregar y dar soporte** (resolución), y alimenta **mejorar**.

4. Las prácticas implicadas en la atención al usuario, que este tema desarrolla:

Práctica ITIL 4	Objetivo
Centro de servicio al usuario (*Service desk*)	Ser el **punto único de contacto** entre el proveedor de servicios y los usuarios
Gestión de incidencias	**Restablecer el servicio normal lo antes posible** minimizando el impacto
Gestión de peticiones de servicio	Atender peticiones previstas y acordadas de forma eficiente y predecible
Gestión de problemas	Reducir la probabilidad e impacto de las incidencias identificando **causas**
Monitorización y gestión de eventos	Observar sistemáticamente los servicios y registrar los cambios de estado significativos
Gestión de niveles de servicio	Fijar objetivos claros de nivel de servicio y evaluar su cumplimiento
Gestión del conocimiento	Mantener y aprovechar la información y el conocimiento de la organización
Mejora continua	Alinear de forma sostenida las prácticas y servicios con las necesidades cambiantes

DATO CLAVE

Definición canónica: una **incidencia** es una **interrupción no planificada de un servicio o una reducción de la calidad de un servicio**. El objetivo de su gestión es **restablecer el servicio normal lo antes posible**, minimizando el impacto adverso en la actividad. **No** es objetivo de la gestión de incidencias hallar la causa raíz: eso corresponde a la **gestión de problemas** [ITIL4].

Esta última frase es la más rentable del tema y conviene entender por qué es así. Cuando un servicio crítico está caído, el objetivo es **devolver el servicio**, aunque sea con una solución temporal —reiniciar, conmutar a un equipo de reserva, aplicar un rodeo—. Investigar la causa mientras cientos de usuarios están parados sería un error de prioridades. La investigación se hace después, sin prisa y con el servicio ya restablecido, dentro de la gestión de problemas. De esta separación se derivan dos indicadores distintos: la gestión de incidencias mide **tiempo de restablecimiento**; la de problemas, **reducción de incidencias recurrentes**.

Ámbito de ITIL en la Administración Pública. ITIL es un marco privado y voluntario, pero se ha convertido en el vocabulario estándar de los **pliegos de contratación de servicios TI** del sector

público: los acuerdos de nivel de servicio, la estructura de niveles de soporte y los indicadores exigidos en los contratos de soporte al puesto están redactados en términos de ITIL. Conocer su vocabulario es, por tanto, un requisito práctico y no solo académico [COBIT2019] [ISO20000].

2.1.2. Ciclo de vida y flujos de trabajo de atención al usuario

El **ciclo de vida de una incidencia** es la secuencia normalizada de estados por los que pasa desde que se detecta hasta que se cierra. Su valor no es burocrático: garantiza que **nada se pierde**, que cualquier técnico puede retomar el trabajo de otro y que existe una traza completa de lo actuado.

Las **ocho etapas** canónicas son [ITIL4] [ISO20000]:

1. **Detección e identificación.** La incidencia llega por un canal (§2.2.2) o la detecta la monitorización antes de que el usuario la note.
2. **Registro.** Se crea el tique con la información mínima obligatoria: identificación del usuario, fecha y hora, canal, descripción del síntoma **en palabras del usuario**, servicio y elemento de configuración afectados. Sin registro no hay gestión: lo que no está en la herramienta, no existe.
3. **Categorización.** Se clasifica según una taxonomía predefinida (§2.2.2), lo que determina el grupo resolutor y alimenta el análisis posterior.
4. **Priorización.** Se calcula la prioridad a partir del **impacto** y la **urgencia** (§2.3.1), lo que fija los tiempos comprometidos.
5. **Diagnóstico inicial.** El primer nivel intenta resolverla con la información disponible, la base de conocimiento y, si procede, una sesión de **asistencia remota**.
6. **Escalado.** Si el primer nivel no puede resolverla en el tiempo previsto, se escala **funcional** o **jerárquicamente** (§2.3.2).
7. **Investigación, diagnóstico y resolución.** El grupo competente identifica qué falla y aplica la solución o el rodeo que restablece el servicio.
8. **Recuperación y cierre.** Se confirma con el usuario que el servicio está restablecido, se documenta la solución y se cierra con una categorización de cierre (§2.3.3).

A lo largo de estas etapas, el tique atraviesa **estados** que la herramienta debe reflejar con exactitud, porque de ellos dependen los relojes del acuerdo de nivel de servicio:

Estado	Significado	¿Cuenta el reloj del SLA?
Nuevo / registrado	Creado, aún sin asignar	Sí
Asignado	Atribuido a un grupo o técnico	Sí
En curso	En diagnóstico o resolución activa	Sí
En espera del usuario	Falta información o disponibilidad del usuario	**Normalmente se detiene**
En espera de terceros	Pendiente de proveedor o de otra área	Según lo pactado
Resuelto	Servicio restablecido, pendiente de confirmación	No
Cerrado	Confirmado y documentado	No
Reabierto	El usuario informa de que el fallo persiste	Sí, y penaliza los indicadores de calidad

DATO CLAVE

Los estados **de espera** («pendiente de usuario», «pendiente de proveedor») **detienen el reloj** del acuerdo de nivel de servicio si así se ha pactado. Por eso su uso debe estar reglado y auditado: usarlos indebidamente para «parar el reloj» es una de las malas prácticas más habituales y falsea por completo los indicadores de cumplimiento [ITIL4] [ISO20000].

Flujos de trabajo diferenciados. No todas las incidencias siguen el mismo camino. Las organizaciones maduras definen al menos cuatro flujos:

- **Flujo estándar**: el descrito arriba, para la mayoría de incidencias.
- **Flujo de incidencia grave** (*major incident*): activado cuando el impacto es crítico. Implica un responsable de incidencia designado, sala de crisis o puente de comunicación, comunicación periódica a los afectados y a la dirección, y revisión posterior. **No espera al escalado normal: se escala de inmediato**.
- **Flujo de incidencia de seguridad**: cuando hay indicios de compromiso, filtración o acceso no autorizado, se activa un procedimiento propio que involucra al responsable de seguridad, preserva evidencias y valora la **notificación al CCN-CERT** y, si hay datos personales, la **notificación de brecha** (§3.2.2) [CCN-STIC] [RGPD].

- **Flujo de petición de servicio**: sin urgencia de restablecimiento, a menudo con autorización previa y con tiempos distintos (§2.4.1).

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
>
> La incidencia de firma de la tramitadora sigue el **flujo estándar**. Si en lugar de un puesto fallaran todos los de la Oficina, o si cayera el servicio de firma de la sede electrónica en toda la ciudad, se activaría el **flujo de incidencia grave**: responsable designado, comunicación a las oficinas afectadas —que deben poder decir algo al ciudadano que espera— y aviso a la dirección. Y si el síntoma fuera que un certificado ha sido usado desde un equipo ajeno, el flujo sería el de **incidencia de seguridad**, con preservación de evidencias antes de tocar el puesto.

2.2. El Centro de Atención a Usuarios (CAU)

2.2.1. Funciones, modelos organizativos y niveles de soporte

El **Centro de Atención a Usuarios (CAU)** —*service desk* en la terminología de ITIL, *help desk* en el uso coloquial— es la unidad organizativa que actúa como **punto único de contacto (SPOC, *Single Point of Contact*)** entre los usuarios y la organización de tecnología. Esa condición de punto **único** es su rasgo definitorio y la fuente de casi todo su valor: el usuario no tiene que saber a qué equipo técnico corresponde su problema, ni perseguir a nadie; llama a un solo sitio y desde ahí se orquesta todo.

> **DATO CLAVE**
>
> El CAU es el **punto único de contacto (SPOC)**. En ITIL v3 era una **función** (una unidad organizativa con personas y herramientas), no un proceso; en **ITIL 4** es una **práctica**. Su valor no está solo en resolver, sino en **registrar, coordinar y comunicar**: es el propietario del tique durante toda su vida, aunque la resolución la ejecute otro grupo [ITIL4] [ITILV3].

Funciones del CAU:

1. **Recibir y registrar** todos los contactos de los usuarios, sea cual sea el canal.
2. **Clasificar y priorizar** cada contacto (incidencia, petición, consulta, evento).
3. **Resolver en primer contacto** todo lo que esté a su alcance: es su indicador estrella (§3.3.1).
4. **Escalar** lo que no puede resolver, sin perder la propiedad del tique.
5. **Informar al usuario** del estado y del plazo previsto, tanto proactiva como reactivamente.
6. **Confirmar la resolución y cerrar**, midiendo la satisfacción.
7. **Alimentar la base de conocimiento** con lo aprendido y detectar patrones que sugieran un problema subyacente.

8. **Ser la fuente de la voz del usuario** para la mejora del servicio: el CAU es el único punto de la organización que sabe qué duele realmente.

Modelos organizativos del CAU, que en la práctica se combinan:

Modelo	Descripción	Cuándo conviene
Local	Un CAU en cada sede, físicamente próximo a los usuarios	Necesidad de presencia física, idioma o normativa local; caro y difícil de homogeneizar
Centralizado	Un único CAU para toda la organización	Eficiencia, homogeneidad de criterios y economía de escala; es el modelo dominante
Virtual	Técnicos dispersos geográficamente que operan como un único CAU mediante la herramienta común	Cobertura amplia, teletrabajo, aprovechamiento de especialistas repartidos
Siguiendo al sol (*follow the sun*)	Varios centros en husos horarios distintos que se relevan	Cobertura 24×7 sin turnos de noche; propio de organizaciones multinacionales
Especializado	Colas o grupos distintos según el tipo de usuario o servicio	Servicios muy técnicos o usuarios con necesidades muy diferenciadas

Niveles de soporte. La estructura por niveles es el mecanismo que hace sostenible la atención: concentra el conocimiento escaso en los niveles altos y resuelve el volumen en los bajos.

Nivel	Quién es	Qué resuelve	Rasgo económico
Nivel 0	El propio usuario	Autoservicio: portal, preguntas frecuentes, restablecimiento autónomo de contraseña, catálogo de peticiones, asistentes automáticos	Coste marginal casi nulo; el más barato por incidencia
Nivel 1	Técnicos generalistas del CAU	Incidencias frecuentes y documentadas; guiones de diagnóstico; **asistencia remota**; peticiones estándar	Alta rotación, formación continua, procedimientos escritos
Nivel 2	Especialistas por ámbito (puesto, red, sistemas, aplicaciones, bases de datos)	Lo que exige conocimiento profundo o permisos elevados	Recurso caro y limitado: hay que protegerlo del ruido
Nivel 3	Expertos, arquitectos, desarrolladores, **fabricante o proveedor**	Defectos de producto, análisis de causa raíz, casos sin precedente	El más caro; a menudo regulado por un contrato de soporte (UC)
Soporte de campo	Técnicos con desplazamiento	Todo lo físico: sustitución de equipos y periféricos, cableado, sedes sin conectividad	Coste dominado por el desplazamiento

DATO CLAVE

El objetivo económico de la estructura por niveles es **resolver el mayor volumen posible en los niveles más bajos**, que son los más baratos. Cada escalado innecesario consume un recurso escaso. Por eso los dos indicadores que mejor miden la salud del modelo son la **tasa de resolución en primer contacto (FCR)** y la **tasa de escalado**: si la FCR baja y el escalado sube, el nivel 1 está infraformado o la base de conocimiento está desactualizada [ITIL4].

Dimensionamiento y organización interna. El CAU se dimensiona a partir del **volumen de contactos por franja horaria**, del **tiempo medio de atención** y del **nivel de servicio comprometido** (por ejemplo, atender el 80 % de las llamadas en menos de 30 segundos). De ahí salen los turnos, los refuerzos en las franjas punta —típicamente el arranque de la mañana y el regreso tras vacaciones o fines de semana largos— y la plantilla necesaria. Un CAU infradimensionado no se manifiesta como falta de resoluciones, sino como **abandono de llamadas** y como usuarios que dejan de llamar y buscan atajos, lo que a su vez oculta la demanda real.

EJEMPLO DE APLICACIÓN EN EL AYTO

Conviene no confundir dos servicios de atención distintos en un ayuntamiento. El **CAU** es un servicio **interno**: atiende a los **empleados municipales** con incidencias en sus herramientas de trabajo. Los servicios de atención a la **ciudadanía** —el teléfono de información municipal, las Oficinas de Atención a la Ciudadanía o el soporte de la sede electrónica— atienden a **vecinos**, y su objeto no es el puesto de trabajo sino el trámite. Los dos se relacionan: si un ciudadano no puede presentar una solicitud porque la sede falla, se abrirá una incidencia técnica que gestionará el CAU o el equipo de la aplicación, pero **el canal de entrada, los usuarios y los compromisos de servicio son distintos**, y confundirlos en un examen o en un pliego es un error de bulto. Conviene retener, además, la razón de fondo por la que el soporte al puesto es un servicio crítico en una Administración: el puesto de trabajo del empleado es el instrumento con el que se ejerce el **derecho de la ciudadanía a relacionarse electrónicamente y a ser asistida en el uso de medios electrónicos** que reconoce la Ley 39/2015 [L39-2015].

2.2.2. Canales de entrada, registro y categorización

Canales de entrada. Un CAU moderno es **multicanal**, y cada canal tiene un perfil distinto de coste, riqueza y trazabilidad:

Canal	Ventajas	Inconvenientes
Teléfono	Inmediato, permite dialogar y acotar rápido; imprescindible cuando el usuario no puede usar el ordenador	Caro, no deja constancia escrita salvo grabación, mal para adjuntar evidencias
Portal de autoservicio	Barato, disponible 24×7, estructura la información desde el origen, permite adjuntar capturas y consultar el estado	Exige que el usuario pueda acceder; peor para incidencias urgentes o confusas
Correo electrónico	Cómodo y familiar, deja constancia	Información desestructurada e incompleta; genera trabajo de reclasificación; sin acuse real de recepción
Chat o asistente conversacional	Inmediato y de bajo coste; permite atender varias conversaciones a la vez y automatizar respuestas frecuentes	Limitado para diagnósticos complejos
Monitorización automática	**Detecta antes de que el usuario lo note**; genera la incidencia sola	Puede generar ruido y falsos positivos si no se afina
Presencial	Insustituible para lo físico	El más caro por contacto

DATO CLAVE

Todos los canales deben desembocar en **un único registro y una única herramienta**. Un CAU multicanal con registros separados por canal pierde la trazabilidad, duplica incidencias y hace imposible medir. La multicanalidad está en la **entrada**, nunca en el **registro** [ITIL4] [ISO20000].

El registro. Los campos mínimos de un tique bien registrado son:

1. **Identificador único** del tique.
2. **Identificación del usuario** y sus datos de contacto y ubicación (sede, planta, unidad).
3. **Fecha y hora de apertura** y **canal** de entrada.
4. **Descripción del síntoma**, preferentemente en las palabras del usuario, y qué ha cambiado recientemente.
5. **Servicio afectado** y **elemento de configuración** implicado (equipo, aplicación, servidor), tomado de la **CMDB**.
6. **Categoría** y **subcategoría**.

7. **Impacto**, **urgencia** y **prioridad** resultante.
8. **Grupo asignado** y técnico responsable.
9. **Diario de actuaciones**: cada intervención, incluida **cada sesión de asistencia remota**, con su hora y su autor.
10. **Solución aplicada** y **categorización de cierre**.

EJERCICIO RESUELTO

Enunciado: un usuario abre un tique por correo con el texto «el ordenador no va». ¿Qué información falta y cómo debe actuar el técnico de primer nivel antes de escalar? **Solución**: el registro es inservible como está. Falta **el síntoma concreto** (¿no enciende, no arranca el sistema, va lento, no abre una aplicación?), **el alcance** (¿solo él o también sus compañeros?), **el momento de inicio** y **qué ha cambiado** (un parche, un traslado, una aplicación nueva), la **identificación del equipo** en el inventario y el **servicio afectado**. La actuación correcta no es escalar —escalar un tique sin diagnosticar traslada el trabajo, no el problema— sino **contactar con el usuario** por teléfono o chat, completar el registro con esas respuestas, consultar la base de conocimiento con los síntomas ya acotados y, si el equipo arranca, **abrir una sesión de asistencia remota** para ver el fallo directamente. Solo si tras ese diagnóstico el caso excede su competencia procede escalar, y entonces el tique llevará ya toda la información necesaria para que el nivel 2 no tenga que empezar de cero. Como mejora estructural, el formulario del portal debería exigir esos campos desde el origen, y el correo desestructurado desincentivarse como canal.

La categorización es la clasificación del tique dentro de una taxonomía predefinida, y cumple cuatro funciones: **encaminar** el tique al grupo adecuado, **seleccionar** el guion de diagnóstico o el artículo de conocimiento aplicable, **alimentar los indicadores** por familia de incidencia y **permitir detectar patrones** que revelen un problema subyacente.

Una taxonomía típica se organiza en tres niveles jerárquicos: **categoría** (hardware, software, red, identidad, aplicación corporativa, telefonía, impresión), **subcategoría** (dentro de hardware: equipo, monitor, impresora, lector de tarjetas) y **tipo de fallo** (no enciende, no reconocido, error al imprimir). Su diseño obedece a tres reglas:

- **Pocas categorías y bien diferenciadas**: una taxonomía con doscientas hojas se usa mal y produce datos inservibles.
- **Categorías excluyentes**: si dos técnicos clasifican distinto el mismo caso, los indicadores mienten.
- **Categorización de apertura y de cierre**: la de apertura refleja lo que **parecía**; la de cierre, lo que **era**. La diferencia sistemática entre ambas es en sí misma un indicador de calidad del primer nivel y una fuente para revisar la taxonomía.

DATO CLAVE

La **categorización de cierre** puede y suele diferir de la de apertura, y esa diferencia es información valiosa, no un error: mide cuánto acierta el primer nivel al clasificar y sirve para depurar la taxonomía y los guiones de diagnóstico. Los análisis de tendencias para la gestión de problemas deben apoyarse en la **categorización de cierre** [ITIL4].

2.3. Proceso de gestión y resolución de incidencias

2.3.1. Priorización, impacto y urgencia

Los recursos de soporte son finitos y las incidencias llegan simultáneamente: **priorizar es la decisión más importante del proceso**. La regla canónica de ITIL es:

> **PRIORIDAD = IMPACTO × URGENCIA**

Donde:

- El **impacto** mide **la magnitud del daño**: a cuántos usuarios afecta, qué criticidad tiene el servicio afectado, si hay pérdida económica, riesgo para la seguridad de las personas, incumplimiento legal o daño reputacional. Responde a *¿a cuánto afecta?*
- La **urgencia** mide **la rapidez con la que el daño se agrava** si no se actúa: si el efecto es inmediato o diferido, si existe un rodeo temporal, si hay un plazo administrativo o legal que vence. Responde a *¿cuánto puede esperar?*

DATO CLAVE

Impacto ≠ urgencia. Una incidencia puede tener **impacto alto y urgencia baja** (falla la copia de seguridad nocturna: afecta a todo el sistema, pero puede resolverse antes de la noche siguiente) o **impacto bajo y urgencia alta** (una sola usuaria no puede firmar, pero un plazo administrativo vence hoy). La **prioridad** es el resultado de cruzar ambas, no de ninguna de ellas por separado [ITIL4].

La matriz habitual es de 3×3 o de 5×5. Con tres niveles en cada eje:

Impacto \ Urgencia	Alta	Media	Baja
Alto	**1 — Crítica**	**2 — Alta**	**3 — Media**
Medio	**2 — Alta**	**3 — Media**	**4 — Baja**
Bajo	**3 — Media**	**4 — Baja**	**5 — Muy baja**

Los **criterios de impacto** deben estar escritos y ser objetivos, para que la clasificación no dependa de quién grite más. Un ejemplo de criterios:

Impacto	Criterio
Alto	Servicio esencial caído; una sede o unidad completa afectada; atención al ciudadano interrumpida; riesgo legal, de seguridad o de protección de datos
Medio	Un grupo de usuarios afectado o servicio degradado con rodeo disponible
Bajo	Un único usuario, con rodeo disponible y sin afectación a la atención al ciudadano

> DATO CLAVE
>
> La priorización **no la decide el usuario**. Que un usuario califique su caso de «urgentísimo» es información a considerar, pero la prioridad se asigna aplicando **criterios objetivos escritos**. Si la prioridad la fija quien más insiste, el sistema de priorización deja de funcionar y las incidencias verdaderamente críticas se retrasan [ITIL4].

Tres matices importantes:

- **La prioridad puede cambiar durante la vida del tique**: si aparecen más afectados, si vence un plazo o si el rodeo deja de funcionar, hay que **reevaluarla** y ajustar los compromisos.
- **La agrupación eleva el impacto**: veinte tiques por la misma causa deben vincularse a una incidencia común cuyo impacto refleje a los veinte afectados, no a uno.
- **La incidencia grave** (*major incident*) no es simplemente la de prioridad 1: es una categoría con **procedimiento propio** —responsable designado, comunicación estructurada y revisión posterior— que se activa por criterios definidos de antemano.

EJERCICIO RESUELTO

Enunciado: clasifique impacto, urgencia y prioridad de estos tres casos, usando la matriz 3×3 anterior. (a) La aplicación de tramitación de licencias está caída en los veintiún distritos, con ciudadanos esperando en los mostradores. (b) Una técnica no puede imprimir un informe interno que debe entregar la semana que viene; puede usar la impresora de la sala contigua. (c) Falla el proceso nocturno de copia de seguridad de un servidor de expedientes; son las diez de la mañana y la próxima ventana de copia es a las once de la noche. **Solución**: - **(a)** Impacto **alto** —servicio esencial caído, toda la organización, atención al ciudadano interrumpida— y urgencia **alta** —el daño se produce ahora mismo, sin rodeo—. Prioridad **1, crítica**, y con toda probabilidad se activa además el procedimiento de **incidencia grave**, con responsable designado y comunicación a las oficinas. - **(b)** Impacto **bajo** —una sola usuaria, servicio interno, sin afectación al ciudadano— y urgencia **baja** —hay rodeo inmediato, la impresora contigua, y el plazo es holgado—. Prioridad **5, muy baja**. Obsérvese que la incidencia es real y debe registrarse y resolverse; simplemente no compite con las anteriores. - **(c)** Impacto **alto** —afecta a la protección de todos los expedientes del servidor: si hubiera que restaurar, no habría copia del día— pero urgencia **media**: el daño no se materializa hasta la noche, y hay margen para corregir antes de la siguiente ventana. Prioridad **2, alta**. Este caso es el que mejor ilustra la independencia de los dos ejes: un impacto alto **no** implica automáticamente prioridad crítica. Ahora bien, si a las diez de la noche siguiera sin resolverse, la urgencia pasaría a alta y la prioridad debería **reevaluarse a crítica**.

2.3.2. Diagnóstico, escalado funcional y jerárquico

El diagnóstico es la fase en la que se convierte un síntoma en una causa accionable. Un método de trabajo razonable en primer nivel sigue estos pasos:

1. **Reproducir o confirmar el síntoma**, idealmente mediante **asistencia remota**: lo que el usuario describe y lo que ocurre no siempre coinciden.
2. **Acotar el alcance**: ¿solo este usuario, este equipo, esta sede, este servicio? La respuesta reorienta por completo la hipótesis (véase el ejercicio de §1.1.2).
3. **Averiguar qué ha cambiado**: la mayoría de las incidencias siguen a un cambio —un parche, una actualización, una modificación de directiva, un traslado, un permiso revocado—. La vinculación con la **gestión de cambios** es aquí decisiva.
4. **Consultar la base de conocimiento y los errores conocidos**: si el caso ya está documentado, la resolución es inmediata (§3.3.2).
5. **Aplicar el guion de diagnóstico** de la categoría, que descarta hipótesis en orden de probabilidad y coste.
6. **Registrar lo comprobado**, incluidas las hipótesis descartadas: es lo que permite que un escalado no empiece de cero.

El escalado es la transferencia del trabajo, o del asunto, a otra instancia. Hay **dos tipos y no deben confundirse**:

DATO CLAVE

Escalado funcional (horizontal): se traslada a un grupo con **mayor conocimiento técnico o mayores permisos** (N1 → N2 → N3 → proveedor). Motivo: *no sé o no puedo resolverlo*. **Escalado jerárquico (vertical)**: se informa o se traslada a un **nivel de autoridad superior** (responsable del CAU, jefatura, dirección). Motivos: se van a incumplir los plazos, hace falta autorizar una parada o un gasto, el impacto es institucional, o hay conflicto de prioridades entre áreas. **El escalado jerárquico no aporta conocimiento técnico: aporta decisión y recursos** [ITIL4].

Reglas de buen escalado:

- **La propiedad del tique no se transfiere**: el CAU sigue siendo responsable de su seguimiento y de informar al usuario aunque otro grupo lo esté resolviendo. Escalar no es «quitárselo de encima».
- **El escalado debe ir documentado**: síntoma, alcance, comprobaciones realizadas y descartadas, y qué se pide exactamente al grupo destinatario.
- **Debe existir un tiempo máximo antes de escalar** por prioridad, para que un tique no se estanque en un nivel que no puede resolverlo.
- **El escalado automático** por incumplimiento de un umbral de tiempo es la salvaguarda que impide que un tique caiga en el olvido; lo configura la herramienta a partir de la matriz de escalado (§2.3.4).
- Ambos escalados **pueden coexistir**: una incidencia grave se escala funcionalmente al especialista **y** jerárquicamente a la dirección al mismo tiempo.

EJEMPLO DE APLICACIÓN EN EL AYTO

Si el técnico de primer nivel comprueba en remoto que el certificado de la tramitadora está caducado, resuelve en primer contacto guiándola en la renovación o generando la petición correspondiente. Si comprueba que el fallo se produce en el **servicio de validación de certificados** de la sede, **escala funcionalmente** al equipo de administración electrónica: no es un problema del puesto y el primer nivel no tiene ni conocimiento ni permisos sobre ese servicio. Y si además detecta que están llamando oficinas de varios distritos con el mismo síntoma —con lo que el impacto pasa a alto y hay ciudadanos esperando—, **escala jerárquicamente** al responsable del CAU para que active el procedimiento de incidencia grave y coordine la comunicación a las oficinas. Los dos escalados son simultáneos y responden a necesidades distintas: uno busca **quien sepa**; el otro, **quien decida**.

2.3.3. Resolución, restablecimiento del servicio y cierre

Resolución frente a restablecimiento. La distinción es sutil:

- **Restablecer el servicio** (*recovery*) es devolver al usuario la capacidad de trabajar, aunque sea con una **solución temporal o rodeo** (*workaround*): reiniciar un servicio, conmutar a un equipo de reserva, entregar un equipo de préstamo, habilitar un procedimiento manual alternativo.
- **Resolver definitivamente** es eliminar la causa del fallo, lo que a menudo **no corresponde a la gestión de incidencias** sino a la de problemas o a la de cambios.

> DATO CLAVE
>
> La gestión de incidencias puede cerrar un tique **con una solución temporal**, siempre que el servicio esté restablecido, el rodeo esté documentado y —si la causa persiste— **se haya abierto el problema correspondiente**. Cerrar con rodeo sin abrir el problema es la práctica que hace que la misma incidencia reaparezca indefinidamente [ITIL4].

Etapas de la resolución:

1. **Aplicar la solución** o el rodeo, evaluando antes su riesgo: reiniciar un servicio compartido puede afectar a más usuarios que la propia incidencia.
2. **Verificar técnicamente** que el servicio funciona, sin conformarse con «debería funcionar».
3. **Confirmar con el usuario** que puede volver a trabajar. La verificación técnica y la del usuario no son la misma cosa: el usuario es quien define si el servicio está restablecido.
4. **Documentar** en el tique qué se hizo exactamente, con qué resultado y por qué.
5. **Cerrar** con categorización de cierre, causa y solución aplicada.

Reglas del cierre:

- **Nunca se cierra sin confirmación del usuario**, salvo por la regla de **cierre automático**: tras un plazo pactado (habitualmente entre tres y cinco días hábiles) sin respuesta del usuario a las peticiones de confirmación, el tique se cierra automáticamente, dejando constancia de los intentos.
- **La reapertura** debe estar acotada en el tiempo: pasado el plazo, un fallo recurrente se registra como **incidencia nueva vinculada** a la anterior, para no distorsionar los tiempos.
- **La encuesta de satisfacción** se lanza al cierre, sobre una muestra o sobre el total.
- **La categorización de cierre**, la causa y la solución alimentan la **base de conocimiento** y el análisis de tendencias.

Una **tasa de reapertura alta** es una de las señales de alarma más fiables de un servicio de soporte: significa que se está cerrando antes de tiempo, quizá para cumplir formalmente el acuerdo de nivel de servicio. Es un ejemplo del riesgo general de las métricas —medir mal induce a comportarse mal— que se trata en §3.3.1.

2.3.4. Matriz de escalado y Acuerdos de Nivel de Servicio (SLA)

Un **Acuerdo de Nivel de Servicio (SLA, *Service Level Agreement*)** es el acuerdo documentado entre el **proveedor del servicio** y el **cliente** que fija los objetivos de nivel de servicio comprometidos y las responsabilidades de ambas partes. Junto a él hay que distinguir otros dos instrumentos:

> DATO CLAVE
>
> **SLA** (*Service Level Agreement*): con el **cliente** o usuario del servicio. **OLA** (*Operational Level Agreement*): acuerdo **interno**, entre equipos de la **propia organización** que sostienen ese servicio. **UC** (*Underpinning Contract*, contrato de soporte): con un **proveedor externo**. Los OLA y los UC deben estar dimensionados de forma que **permitan cumplir el SLA**: no se puede comprometer una resolución en cuatro horas con el cliente si el contrato con el fabricante que debe aportar la pieza garantiza cuarenta y ocho [ITIL4] [ISO20000].

Contenido típico de un SLA de soporte al puesto:

Elemento	Ejemplo
Servicios cubiertos y exclusiones	Puesto de trabajo estándar; se excluye el equipamiento personal
Horario de servicio	De 8:00 a 18:00 en días hábiles; guardia 24×7 para servicios esenciales
Tiempo de respuesta	Tiempo hasta el primer contacto efectivo con el usuario
Tiempo de resolución	Tiempo hasta el restablecimiento del servicio
Objetivos de disponibilidad	Porcentaje de disponibilidad mensual del servicio
Objetivos de atención	Porcentaje de llamadas atendidas antes de N segundos; tasa máxima de abandono
Procedimiento de escalado	Matriz de escalado con umbrales y destinatarios
Régimen de informes	Informe mensual de cumplimiento y comité de seguimiento
Penalizaciones	Consecuencias del incumplimiento, cuando el servicio está contratado
Exclusiones del cómputo	Paradas planificadas, fuerza mayor, tiempo en espera del usuario

DATO CLAVE

Tiempo de respuesta ≠ tiempo de resolución. El de **respuesta** mide desde el registro hasta el **primer contacto efectivo** o la asignación; el de **resolución**, hasta el **restablecimiento del servicio**. Un CAU puede cumplir escrupulosamente el tiempo de respuesta y estar incumpliendo de forma sistemática el de resolución: por eso ambos se miden y se informan por separado [ITIL4].

Un cuadro de tiempos comprometidos, ligado a la prioridad, tiene esta forma (los valores son ilustrativos: los reales se pactan en cada contrato):

Prioridad	Tiempo de respuesta	Tiempo de resolución	Escalado automático
1 — Crítica	15 minutos	4 horas	A N2 a los 30 min; jerárquico a la hora
2 — Alta	1 hora	8 horas laborables	A N2 a las 2 h; jerárquico a las 6 h
3 — Media	4 horas	2 días laborables	A N2 al día; jerárquico al segundo día
4 — Baja	1 día laborable	5 días laborables	A N2 a los 3 días
5 — Muy baja	2 días laborables	10 días laborables	Bajo demanda

La **matriz de escalado** es el documento que traduce esos umbrales en actuaciones concretas: **qué** dispara el escalado (tiempo transcurrido, prioridad, número de afectados, tipo de servicio), **a quién** se escala en cada tramo horario —con nombres, cargos y datos de contacto, incluida la guardia—, **por qué medio** y **con qué información**. Debe estar **publicada, actualizada y probada**: una matriz de escalado con teléfonos obsoletos se descubre siempre en la peor noche posible.

EJERCICIO RESUELTO

Enunciado: el SLA compromete la resolución de las incidencias críticas en **4 horas**. El fabricante del equipamiento garantiza en su contrato la sustitución de piezas en **siguiente día laborable**. Un servidor esencial sufre una avería de disco. ¿Se puede cumplir el SLA? ¿Qué falla en el diseño y cómo se corrige? **Solución**: **no se puede cumplir** por la vía de la sustitución de la pieza: el **UC** con el fabricante (siguiente día laborable) no sostiene el **SLA** con el cliente (4 horas). Es el error de diseño clásico: comprometer con el cliente un nivel que la cadena de acuerdos internos y externos no puede sostener. Hay dos formas de corregirlo, y son alternativas legítimas: **(a) elevar el UC**, contratando un soporte de cuatro horas con reposición en sitio para el equipamiento esencial —lo que cuesta dinero y por eso debe reservarse a lo verdaderamente crítico—; o **(b) diseñar el servicio para no depender de la pieza**, con redundancia (matriz de discos tolerante a fallos, servidor en alta disponibilidad, repuesto propio en almacén), de modo que el **servicio se restablezca en minutos** aunque la pieza tarde un día en llegar. Obsérvese que la opción (b) es coherente con la distinción de §2.3.3: lo que el SLA compromete es **restablecer el servicio**, no reparar el componente averiado. En la práctica, la combinación de redundancia más stock propio de repuestos suele ser más barata y más fiable que un contrato de respuesta ultrarrápida.

2.4. Gestión de peticiones de servicio y eventos

2.4.1. Diferencias entre incidencia, problema y petición

Estas tres definiciones, junto con la de **evento** y la de **error conocido**, forman el núcleo terminológico del tema y aparecen en prácticamente todos los exámenes.

Objeto	Definición	Objetivo de su gestión	Ejemplo
Incidencia	Interrupción **no planificada** de un servicio o reducción de su calidad	**Restablecer** el servicio lo antes posible	La impresora de la oficina no imprime
Problema	**Causa, o causa potencial**, de una o varias incidencias	Identificar la **causa raíz** y reducir incidencias futuras	El controlador de impresión de la versión X falla tras el último parche
Error conocido	Problema **ya analizado**, del que se conoce la causa y/o una solución temporal	Documentarlo para acelerar futuras resoluciones	Se conoce el fallo y el rodeo: usar el controlador genérico
Petición de servicio	Solicitud **prevista y acordada** dentro de la prestación normal del servicio	Atenderla de forma **eficiente y predecible**	Solicitar la instalación de una aplicación del catálogo
Evento	**Cambio de estado significativo** de un elemento de configuración o servicio	Detectar y decidir si requiere acción	La cola de impresión supera los 200 trabajos

DATO CLAVE

La diferencia decisiva entre **incidencia** y **petición** es que en la incidencia **algo se ha roto** —hay una interrupción o degradación no planificada— mientras que en la petición **nada está roto**: el usuario solicita algo que la organización ya ha previsto ofrecer. Consecuencias prácticas: la petición suele requerir **autorización previa** (del responsable o del propietario del dato), suele estar **catalogada con un precio o un coste** y se mide por **cumplimiento de plazo**, no por rapidez de restablecimiento [ITIL4] [ISO20000].

La gestión de peticiones de servicio se apoya en un **catálogo de servicios** que actúa como escaparate: para cada petición se define quién puede solicitarla, qué autorización requiere, qué plazo tiene comprometido, quién la ejecuta y qué coste tiene. Peticiones típicas del puesto de trabajo:

- Alta, baja o modificación de una cuenta de usuario y de sus permisos.
- Restablecimiento de contraseña (candidata número uno a la automatización en el nivel 0).
- Instalación de una aplicación del catálogo.
- Asignación o sustitución de equipo o de periférico.
- Acceso a una carpeta compartida o a una aplicación corporativa.

- Alta de un buzón, una lista de distribución o una firma.
- Traslado de un puesto a otra ubicación.

Su valor está en la **predictibilidad y la automatización**: al ser previsibles, se pueden convertir en flujos automáticos con autorización electrónica, lo que descarga al CAU y mejora la experiencia. Una parte muy grande del volumen de contactos de un CAU típico son peticiones, no incidencias; distinguirlas es imprescindible para dimensionar y para medir, porque mezclar ambas en un mismo indicador de «tiempo de resolución» produce cifras sin sentido.

La gestión de eventos y la monitorización. Un **evento** es cualquier cambio de estado que tenga significado para la gestión de un servicio. Se clasifican en tres tipos [ITIL4]:

1. **Informativo**: registra algo que ha ocurrido según lo previsto (una copia de seguridad se completó, un usuario inició sesión). No requiere acción.
2. **Advertencia** (*warning*): algo se aproxima a un umbral y conviene actuar **antes** de que falle (el disco está al 85 %, la temperatura sube). Es la categoría que permite el **soporte proactivo**.
3. **Excepción**: algo ha superado el umbral o ha fallado (servicio caído, disco lleno, error de autenticación repetido). Genera normalmente una **incidencia automática**.

> DATO CLAVE
>
> La **advertencia** es la categoría de mayor valor económico de las tres: permite evitar la incidencia en lugar de resolverla. Un servicio de soporte maduro se reconoce en que una parte creciente de su trabajo procede de **eventos de advertencia** y no de llamadas de usuarios [ITIL4] [NAGIOS].

El riesgo característico de la monitorización es el **exceso de alertas**: si el sistema genera miles de eventos irrelevantes, los operadores dejan de mirarlos y la alerta importante se pierde entre el ruido. Las técnicas de control son la **correlación** de eventos —un enlace caído genera cien alertas de los servicios que dependen de él; hay que emitir **una** con la causa—, la **supresión durante ventanas de mantenimiento** y el **ajuste continuo de umbrales**.

> RELACIÓN CON OTROS TEMAS
>
> La **monitorización y el control de tráfico** en el ámbito de la red local corresponden al **Tema 30**, y los protocolos de monitorización se citan en §1.3.1 de este tema. Aquí interesa el evento como **origen de incidencias** y como palanca de soporte proactivo.

2.4.2. Integración de la gestión de incidencias con la gestión de problemas

La gestión de incidencias y la de problemas son **complementarias y de naturaleza opuesta**: la primera es **reactiva y urgente** —cuanto antes vuelva el servicio, mejor—; la segunda es **analítica y sin prisa** —cuanto mejor se entienda la causa, mejor—. Confundirlas produce los dos errores

clásicos: investigar la causa mientras el servicio está caído, o restablecer una y otra vez sin investigar nunca.

Cuándo se abre un problema. Los disparadores habituales son:

- **Incidencias recurrentes** con el mismo patrón, aunque cada una se resuelva sin dificultad.
- Una **incidencia grave**, en la que la apertura del problema suele ser obligatoria tras la revisión posterior.
- Una incidencia resuelta **solo con un rodeo**, cuya causa sigue viva.
- **Análisis proactivo de tendencias** sobre los datos de cierre: qué categorías crecen, qué elementos de configuración concentran fallos.

El ciclo de la gestión de problemas tiene tres fases [ITIL4]:

1. **Identificación del problema**: detección, registro, categorización y priorización, con los mismos criterios de impacto y urgencia pero aplicados al **daño acumulado** que causa.
2. **Control del problema**: análisis de la **causa raíz** (con técnicas como los *cinco porqués*, el diagrama de causa-efecto o el análisis de Kepner-Tregoe), documentación como **error conocido** y publicación de la **solución temporal** para que el CAU pueda aplicarla de inmediato en futuras incidencias.
3. **Control del error**: gestión de la solución definitiva, que casi siempre se implanta a través de la **gestión de cambios** —un parche, una nueva versión, un cambio de configuración— y, por tanto, con evaluación de riesgo, ventana y plan de reversión.

> DATO CLAVE
>
> La **base de datos de errores conocidos (KEDB)** es el punto de contacto operativo entre ambas prácticas: la gestión de problemas la **escribe** y la gestión de incidencias la **consulta**. Gracias a ella, una incidencia cuya causa ya está analizada se resuelve en minutos aplicando el rodeo documentado, sin diagnosticar de nuevo. Es el mecanismo que más eleva la resolución en primer contacto [ITIL4].

Relación con la gestión de cambios y de configuración. Tres vínculos que conviene retener:

- Una parte muy alta de las incidencias **sigue a un cambio**. Por eso lo primero que se consulta en un diagnóstico es el registro de cambios recientes sobre el elemento afectado.
- La solución definitiva de un problema **es un cambio**, y como tal debe planificarse, evaluarse y poder revertirse; aplicarla «en caliente» reintroduce el riesgo que se pretendía eliminar.
- La **CMDB** sostiene ambas prácticas: sin saber qué elementos hay y **de qué depende cada servicio**, no puede evaluarse el impacto de una incidencia ni el alcance de un cambio.

EJEMPLO DE APLICACIÓN EN EL AYTO

Volviendo al caso de referencia: si en dos semanas se registran ciento cuarenta incidencias de firma electrónica en oficinas de varios distritos, cada una resuelta individualmente con el mismo rodeo, la gestión de incidencias está funcionando **y el servicio está fallando**. Lo correcto es **abrir un problema**, analizar la causa raíz —por ejemplo, la incompatibilidad entre una versión del navegador desplegada por el parcheo automático y la versión del middleware criptográfico del parque—, documentarla como **error conocido** con su rodeo, y planificar la solución definitiva como un **cambio**: desplegar la versión compatible del middleware a todo el parque desde la plataforma de gestión centralizada (§1.3.4) y retener la actualización del navegador hasta que ese despliegue termine. El resultado se mide en la caída de una familia entera de incidencias, no en el tiempo de resolución de cada una.

EJERCICIO RESUELTO

Enunciado: clasifique cada uno de estos cinco casos como incidencia, problema, error conocido, petición de servicio o evento. (a) Un usuario solicita acceso a la carpeta compartida de su unidad. (b) El servidor de correo notifica que el espacio de disco alcanza el 90 %. (c) Un usuario no puede abrir su correo. (d) Se documenta que la aplicación de expedientes falla al exportar a PDF con la versión 12.3 del visor, y que el rodeo es exportar antes a otro formato. (e) Se detecta que veinte usuarios de tres sedes distintas han sufrido el mismo error de exportación esta semana. **Solución**: - **(a) Petición de servicio**: nada está roto; es una solicitud prevista en el catálogo, que además requerirá **autorización** del responsable de la información. - **(b) Evento de advertencia**: aún no hay interrupción, pero se aproxima un umbral. Bien gestionado, genera una tarea de mantenimiento preventivo y **evita** la incidencia; mal gestionado, se convierte en una incidencia crítica cuando el disco llegue al 100 %. - **(c) Incidencia**: hay una interrupción no planificada del servicio para ese usuario. Se registra, se prioriza y se resuelve restableciendo el servicio. - **(d) Error conocido**: hay un problema ya analizado, con causa identificada y **rodeo documentado**. Va a la KEDB para que el primer nivel resuelva en el acto los casos futuros. - **(e) Problema**: la recurrencia y la dispersión geográfica revelan una causa común subyacente que hay que analizar. Nótese que (d) y (e) describen el mismo asunto en momentos distintos de su ciclo: (e) es la **identificación del problema** y (d) es el resultado de su **control**, ya con la causa acotada y el rodeo publicado.

3. Marco normativo, seguridad y calidad en la Administración Pública

> **Material complementario.** El enunciado oficial de este tema no nombra este apartado. Se mantiene porque sitúa la materia en el Ayuntamiento y en la normativa que le aplica, pero lo exigible es lo que enumera el título del tema.

3.1. Seguridad en la asistencia remota

3.1.1. Control de accesos y principio de mínimo privilegio

La asistencia remota concede a un técnico **el mayor privilegio que existe sobre un puesto**: ver todo lo que ve el usuario y hacer todo lo que él puede hacer, a menudo con permisos administrativos añadidos. Esa concentración de poder es exactamente lo que un atacante busca, y por eso las herramientas de asistencia son un objetivo recurrente: comprometer la consola de asistencia equivale a comprometer todo el parque de una vez.

El **principio de mínimo privilegio** establece que todo sujeto debe disponer **únicamente** de los permisos imprescindibles para desempeñar su función, y **solo durante el tiempo necesario**. Aplicado a la asistencia remota se concreta en seis reglas [ENS] [ISO27001]:

1. **Perfiles diferenciados por nivel** (RBAC): el nivel 1 puede ver y controlar puestos de usuario; el nivel 2 añade ejecución de órdenes y acceso desatendido; solo los administradores alcanzan servidores.
2. **Alcance limitado**: cada técnico solo alcanza el **conjunto de equipos** que le corresponde. Un parque municipal debe segmentarse por áreas y distritos, no ofrecerse íntegro a cualquier técnico.
3. **Cuentas nominales y separación de cuentas**: la cuenta ofimática del técnico no es la cuenta con la que administra. Las cuentas genéricas compartidas están prohibidas de facto, porque destruyen la trazabilidad.
4. **Elevación temporal y justificada**: los permisos administrativos se conceden para una ventana concreta, ligada a un tique, y caducan solos.
5. **Modo mínimo suficiente**: si basta con ver, no se controla; si basta con consultar un registro en remoto, no se toma el escritorio.
6. **Revisión periódica de los derechos concedidos**: quien cambia de puesto conserva permisos que ya no necesita si nadie los revisa; es la acumulación silenciosa de privilegios.

> DATO CLAVE
>
> El **mínimo privilegio** tiene dos dimensiones que hay que citar juntas: **qué** permisos (los imprescindibles) y **durante cuánto tiempo** (solo el necesario). Se completa con la **segregación de funciones**, que impide que una misma persona concentre capacidades incompatibles —por ejemplo, administrar la herramienta de asistencia y auditar sus registros— [ENS] [ISO27001].

Controles complementarios que endurecen el acceso:

- **Autenticación multifactor obligatoria** para todo perfil con capacidad de control remoto.
- **Equipos de administración dedicados**, fortificados y sin navegación general, para las tareas de mayor privilegio.

- **Acceso a través de bastión o pasarela** (*jump host*), de modo que ninguna consola de gestión sea alcanzable directamente desde la red de usuarios.
- **Restricción por origen y por horario**: la administración solo desde el segmento de gestión; los accesos fuera de horario, justificados y alertados.
- **Inventario y control de las herramientas instaladas**: una herramienta de asistencia remota instalada por un usuario a título particular es una puerta trasera no gestionada, y su detección debe generar incidencia de seguridad.
- **Gestión del ciclo de vida del técnico**: al causar baja o cambiar de función, la retirada de sus accesos debe ser inmediata y verificada.

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
> Un técnico de primer nivel del CAU necesita tomar el control de puestos de las Oficinas de Atención a la Ciudadanía; no necesita —ni debe poder— tomar el puesto de una persona de la Asesoría Jurídica ni el de un cargo directivo, ni acceder desatendido a ningún equipo. Ese ajuste no se logra con una instrucción escrita, sino **configurando el alcance de su perfil** en la herramienta. Y si un día necesitase excepcionalmente ese acceso, la vía correcta es una **elevación temporal autorizada y registrada**, no un permiso permanente concedido «por si acaso».

3.1.2. Trazabilidad, auditoría y registro de actividades de asistencia

La **trazabilidad** es una de las cinco dimensiones de seguridad del ENS y significa que las actuaciones sobre el sistema puedan **atribuirse inequívocamente a una persona o entidad determinada** y reconstruirse en el tiempo. En la asistencia remota es especialmente exigible: se accede a datos personales de terceros —los ciudadanos cuyos expedientes están abiertos en la pantalla— en nombre de una función de soporte.

Qué debe registrarse de cada sesión de asistencia:

Dato	Por qué
Identidad nominal del técnico	Atribución: sin ella no hay trazabilidad ni responsabilidad
Equipo y usuario atendidos	Objeto de la actuación
Marca de tiempo de inicio y fin	Duración y reconstrucción de la secuencia
Tique asociado	**Justificación**: toda sesión debe responder a una causa registrada
Modo de la sesión (vista, control, desatendida)	Nivel de intrusión aplicado
Consentimiento del usuario, cuando proceda	Prueba de la asistencia atendida
Acciones sensibles: transferencia de ficheros, uso del portapapeles, elevación de privilegios, ejecución de órdenes	Son las vías de exfiltración y de cambio no controlado
Resultado y anotación en el diario del tique	Cierre del círculo con la gestión de incidencias

Grabación de sesiones. Algunas herramientas permiten grabar en vídeo la sesión completa. Es una medida potente para los accesos de mayor privilegio y para los desatendidos, pero **no es inocua**: la grabación captura la pantalla del empleado, con su correo, sus documentos y datos personales de terceros. Su implantación exige base jurídica, **información previa** al personal y a la representación de los trabajadores, finalidad limitada (auditoría de seguridad, no control laboral encubierto), **plazo de conservación** definido, cifrado y acceso restringido a los auditores [RGPD] [LOPDGDD].

> DATO CLAVE
>
> Los registros de actividad deben ser **íntegros y protegidos frente a manipulación**, incluida la del propio administrador: se centralizan en un sistema **independiente** del sistema auditado, con control de acceso propio y con un **plazo de conservación** definido. Un registro que el propio administrador puede borrar no acredita nada [ENS] [ISO27001].

Sincronización horaria. Sin una **fuente de tiempo común y fiable** para todos los sistemas, los registros de distintos equipos no pueden correlacionarse y la reconstrucción de una secuencia de hechos se vuelve discutible. Es un requisito explícito de los sistemas sujetos al ENS y una de las carencias más habituales en auditoría.

Revisión y auditoría. Registrar no basta: hay que **revisar**. Las prácticas maduras incluyen revisión periódica de accesos desatendidos y fuera de horario, alertas automáticas ante patrones anómalos —un técnico que toma cincuenta puestos distintos en una hora, o accesos a equipos fuera de su alcance habitual—, y auditorías internas de una muestra de sesiones contrastando cada una con su tique. Precisamente **la sesión sin tique asociado** es el hallazgo de auditoría más significativo, porque revela un acceso sin justificación registrada.

3.2. Cumplimiento normativo y Esquema Nacional de Seguridad

3.2.1. Requisitos del Esquema Nacional de Seguridad (ENS)

El **Esquema Nacional de Seguridad**, regulado por el **Real Decreto 311/2022, de 3 de mayo**, establece la política de seguridad en la utilización de medios electrónicos por las Administraciones Públicas. Es de **obligado cumplimiento** para el sector público —y, por extensión contractual, para los proveedores que le prestan servicios—, y su finalidad es crear las condiciones de confianza necesarias para el ejercicio de derechos y el cumplimiento de deberes por medios electrónicos [ENS]. Desarrolla el mandato de seguridad del funcionamiento electrónico del sector público contenido en la Ley 40/2015 [L40-2015], y tiene su norma gemela en materia de interoperabilidad en el **Esquema Nacional de Interoperabilidad** (RD 4/2010) [ENI].

Las cinco dimensiones de seguridad que el ENS obliga a valorar en cada sistema son:

> DATO CLAVE
>
> Dimensiones del ENS: **Disponibilidad (D), Autenticidad (A), Integridad (I), Confidencialidad (C) y Trazabilidad (T)**. Cada una se valora en tres niveles —**BAJO, MEDIO y ALTO**— y la **categoría del sistema** (**BÁSICA, MEDIA o ALTA**) la determina el **nivel más alto** alcanzado por cualquiera de sus dimensiones [ENS] [CCN-STIC].

Los principios básicos del ENS, que orientan toda decisión de seguridad, son la seguridad como **proceso integral**, la **gestión de la seguridad basada en los riesgos**, la **prevención, detección, respuesta y conservación**, la **existencia de líneas de defensa**, la **vigilancia continua y reevaluación periódica** y la **diferenciación de responsabilidades**. Junto a ellos, el ENS fija **requisitos mínimos** —desde la organización e implantación del proceso de seguridad hasta el control de acceso, el registro de actividad, la gestión de incidentes y la continuidad—.

Las medidas del Anexo II se agrupan en tres bloques, y conviene conocer los grupos aunque no cada medida:

Bloque	Grupos	Relación con este tema
Marco organizativo (org)	Política, normativa y procedimientos de seguridad; proceso de autorización	La normativa que regula quién puede tomar el control de un puesto y con qué autorización
Marco operacional (op)	Planificación (`op.pl`), **control de acceso** (`op.acc`), **explotación** (`op.exp`), servicios externos (`op.ext`), servicios en la nube (`op.nub`), continuidad (`op.cont`), **monitorización** (`op.mon`)	Identificación y autenticación de los técnicos, gestión de derechos de acceso, **registro de la actividad**, **gestión de incidentes** y detección
Medidas de protección (mp)	Instalaciones, **personal** (`mp.per`), **equipos** (`mp.eq`), **comunicaciones** (`mp.com`), soportes, aplicaciones, información y servicios	Bloqueo del puesto, protección de portátiles, cifrado y autenticidad del canal, separación de flujos de red

Las medidas más directamente aplicables a este tema son las de **control de acceso** (identificación nominal, requisitos de acceso, segregación de funciones, gestión de derechos y mecanismos de autenticación), las de **explotación** relativas al **registro de la actividad**, a su **protección** y a la **gestión de incidentes**, las de **monitorización** y las de **protección de las comunicaciones** (confidencialidad, autenticidad e integridad del canal, y separación de flujos en la red) [ENS].

Otras obligaciones del ENS con impacto directo en el CAU:

- **Gestión de incidentes de seguridad**: procedimiento documentado, registro, y **notificación** de los incidentes que superen el umbral establecido al **CCN-CERT**, con la taxonomía y los criterios de peligrosidad e impacto de las guías CCN-STIC [CCN-STIC].
- **Auditoría de la seguridad**: los sistemas de categoría **MEDIA y ALTA** se someten a **auditoría al menos cada dos años**, y las de categoría **BÁSICA** admiten **autoevaluación**; cualquier modificación sustancial obliga a repetirla.
- **Conformidad y su publicidad**: declaración de conformidad para la categoría básica y **certificación** para las categorías media y alta, con distintivo publicado en la sede electrónica.
- **Responsables diferenciados**: el ENS distingue las figuras de **responsable de la información**, **responsable del servicio**, **responsable de la seguridad** y **responsable del sistema**, con la exigencia de que la responsabilidad de la seguridad esté **diferenciada** de la de la explotación del sistema.
- **Cadena de suministro**: cuando el soporte está externalizado, las obligaciones se trasladan **contractualmente** al proveedor, que debe acreditar su propia conformidad con el ENS.

RELACIÓN CON OTROS TEMAS

Los **principios básicos del Esquema Nacional de Seguridad y del Esquema Nacional de Interoperabilidad** son objeto específico del **Tema 39**, donde se desarrollan con detalle; los **conceptos generales de seguridad de los sistemas de información**, del **Tema 32**. Este epígrafe se limita a los requisitos que condicionan la **asistencia remota y la gestión de incidencias**.

EJEMPLO DE APLICACIÓN EN EL AYTO

Un sistema municipal que da soporte a la tramitación de expedientes con datos de ciudadanos tendrá, como mínimo, niveles medios en confidencialidad, integridad y trazabilidad, lo que sitúa al sistema en **categoría MEDIA o superior** y obliga, entre otras cosas, a **auditoría bienal**. Para el CAU eso se traduce en obligaciones concretas y comprobables: cuentas nominales sin excepciones, autenticación reforzada para el personal de soporte, cifrado de todas las sesiones de asistencia, registro íntegro de cada intervención asociada a su tique, conservación de esos registros durante el plazo fijado y procedimiento escrito de gestión de incidentes con criterios de notificación al CCN-CERT.

3.2.2. Protección de datos personales en la atención de incidencias

Durante una sesión de asistencia remota, el técnico accede —de hecho, aunque no lo pretenda— a **datos personales de terceros**: expedientes, correos, listados, bases de datos abiertas en la pantalla del usuario. Ese acceso es un **tratamiento de datos personales** y está sujeto al RGPD y a la LOPDGDD [RGPD] [LOPDGDD].

Principios aplicables (art. 5 RGPD) y su traducción operativa:

Principio	Traducción en la asistencia remota
Licitud y limitación de la finalidad	Se accede **solo** para resolver la incidencia registrada, nunca para otra cosa
Minimización de datos	Pedir al usuario que **cierre lo que no sea necesario**; usar «solo vista» cuando baste; no navegar por carpetas ajenas al problema
Exactitud	No alterar datos del usuario; si hay que modificar algo, hacerlo con su conocimiento
Limitación del plazo de conservación	Las capturas, registros y grabaciones se conservan el **plazo definido**, no indefinidamente
Integridad y confidencialidad	Canal cifrado, deber de secreto del técnico, control de la transferencia de ficheros
Responsabilidad proactiva	Poder **demostrar** el cumplimiento: procedimientos escritos, registros, formación acreditada

Obligaciones concretas que hay que saber citar:

- **Deber de confidencialidad** del personal de soporte, que **subsiste tras el fin de la relación laboral** [LOPDGDD].
- **Encargado del tratamiento (art. 28 RGPD)**: si el soporte está externalizado o si la herramienta de asistencia es un servicio en la nube de un tercero, ese proveedor es **encargado del tratamiento** y debe existir un **contrato** que fije objeto, duración, finalidad, tipo de datos, obligaciones de seguridad, régimen de subcontratación y devolución o supresión al terminar.
- **Transferencias internacionales**: si el servidor de mediación o el almacenamiento de las grabaciones están fuera del Espacio Económico Europeo, hay que analizar la base de la transferencia. Es una de las razones por las que muchas Administraciones exigen despliegue del servidor de mediación **en sus propias instalaciones** o alojamiento en la Unión Europea.
- **Protección de datos desde el diseño y por defecto (art. 25 RGPD)**: la herramienta debe venir configurada, **de fábrica y por defecto**, en el modo menos intrusivo —consentimiento obligatorio, indicador visible, transferencia de ficheros deshabilitada— y no al revés.
- **Registro de actividades de tratamiento (art. 30 RGPD)**: la actividad de soporte técnico debe figurar en él.
- **Notificación de brechas (arts. 33 y 34 RGPD)**: si durante una asistencia se produce o se descubre una brecha —acceso no autorizado, pérdida o divulgación indebida—, hay que notificarla a la autoridad de control **sin dilación indebida y, de ser posible, en un plazo**

máximo de 72 horas desde que se tuvo constancia, y a los interesados cuando entrañe alto riesgo para sus derechos y libertades.

- **Derechos digitales en el ámbito laboral (arts. 87-91 LOPDGDD)**: el empleado tiene **derecho a la intimidad frente al uso de dispositivos digitales** puestos a su disposición. La organización puede establecer criterios de uso y control, pero debe **informar previamente** al personal y a la representación de los trabajadores. Esto afecta de lleno a la asistencia desatendida y a la grabación de sesiones.

DATO CLAVE

Dos plazos y una regla clave: la **notificación de una brecha de datos personales** a la autoridad de control debe hacerse **sin dilación indebida y, a ser posible, en 72 horas**; la comunicación **a los afectados** procede cuando la brecha entrañe **alto riesgo** para sus derechos y libertades. Y la regla: el acceso del técnico a datos personales durante una asistencia solo es lícito **para la finalidad de resolver la incidencia registrada** [RGPD].

EJERCICIO RESUELTO

Enunciado: durante una sesión de asistencia remota para resolver un problema de impresión, el técnico observa en la pantalla del usuario un documento con datos de salud de un ciudadano y, además, se percata de que el usuario tiene abierta una carpeta compartida a la que —a su juicio — no debería tener acceso. ¿Cómo debe actuar? **Solución**: cuatro actuaciones, en este orden. **(1) No leer ni copiar** el documento: el acceso solo es lícito para la finalidad de resolver la incidencia de impresión, y el dato de salud pertenece además a una **categoría especial**. Lo correcto es pedir al usuario que **cierre o minimice** lo que no sea necesario, lo que además es la aplicación práctica del principio de **minimización**. **(2) No capturar pantalla** de ese contenido para el tique: las evidencias adjuntas deben limitarse a lo imprescindible y estar libres de datos personales ajenos al caso; si una captura es necesaria, debe **anonimizarse**. **(3) Terminar la incidencia** por la que fue llamado, y solo esa. **(4) Comunicar el posible acceso indebido a la carpeta** por el **cauce establecido** —responsable de seguridad o responsable de la información—, **sin investigarlo por su cuenta**: el técnico ha detectado un indicio, no le corresponde ni valorar la licitud del permiso ni auditar accesos. Se registra como **incidencia de seguridad** independiente, con su propio flujo (§2.1.2), y será quien corresponda quien determine si hubo un permiso mal concedido y si constituye una **brecha** notificable. El error a evitar es el opuesto en los dos extremos: ni curiosear, ni callar.

3.3. Medición y mejora continua del servicio

3.3.1. Indicadores clave de rendimiento (KPI) y métricas de servicio

Un servicio que no se mide no puede mejorarse ni defenderse ante quien lo financia. Los indicadores del CAU se agrupan en cuatro familias:

1. Volumen y demanda:

Indicador	Qué mide	Para qué sirve
Número de contactos por periodo y por canal	Carga de trabajo real	Dimensionar plantilla y turnos
Incidencias frente a peticiones	Naturaleza de la demanda	Detectar oportunidades de automatización
Distribución por categoría y por servicio	Dónde duele	Priorizar la gestión de problemas
Distribución horaria	Franjas punta	Planificar refuerzos
Trabajo pendiente (*backlog*) y su antigüedad	Deuda acumulada	Alerta temprana de saturación

2. Eficacia de la resolución:

Indicador	Definición	Comentario
FCR (resolución en primer contacto)	Porcentaje resuelto por el nivel 1 en el primer contacto, sin escalar	El indicador estrella: barato para la organización y excelente para el usuario
Tasa de escalado	Porcentaje escalado a niveles superiores	Complementario del anterior; su subida indica déficit de formación o de conocimiento
MTTR (tiempo medio de restablecimiento)	Media del tiempo hasta restablecer el servicio	Debe analizarse **por prioridad**: la media global oculta el comportamiento en lo crítico
Cumplimiento del SLA	Porcentaje de tiques dentro del plazo comprometido	Se informa por separado para respuesta y para resolución
Tasa de reapertura	Porcentaje de tiques reabiertos tras el cierre	Señal de cierres prematuros o de soluciones incompletas

3. Calidad de la atención:

Indicador	Definición
ASA (tiempo medio de respuesta)	Tiempo medio hasta que se atiende la llamada
Nivel de servicio telefónico	Porcentaje de llamadas atendidas antes de N segundos (por ejemplo, 80 % en 30 s)
Tasa de abandono	Porcentaje de usuarios que cuelgan antes de ser atendidos
CSAT	Satisfacción declarada tras la resolución
Tasa de desvío al autoservicio	Porcentaje de asuntos resueltos en el nivel 0 sin intervención humana

4. Eficiencia y coste: coste medio por contacto y por canal —el autoservicio es un orden de magnitud más barato que el teléfono, y este que el desplazamiento—, número de contactos por técnico y hora, y proporción de trabajo **proactivo** (procedente de eventos de advertencia) frente a **reactivo**.

> DATO CLAVE
>
> Los indicadores deben ser **SMART**: específicos, medibles, alcanzables, relevantes y acotados en el tiempo. Y deben **equilibrarse entre sí**: medir solo el volumen resuelto por técnico premia cerrar rápido y mal; por eso la productividad se contrasta siempre con la **tasa de reapertura** y con la **satisfacción**. Un indicador aislado siempre se puede maximizar a costa del servicio [ITIL4] [COBIT2019].

Malas prácticas frecuentes en la medición, todas ellas ejemplos del mismo fenómeno —el indicador se convierte en objetivo y deja de medir la realidad—:

- Cerrar tiques sin confirmación del usuario para cumplir el plazo.
- Abusar del estado «en espera del usuario» para **detener el reloj** del SLA.
- Trocear una incidencia en varios tiques para inflar el volumen resuelto.
- Registrar como petición lo que es incidencia, o al revés, para acogerse a plazos más holgados.
- Presentar **medias globales** que ocultan el mal comportamiento en las prioridades críticas: siempre hay que segmentar por prioridad y por servicio.

EJERCICIO RESUELTO

Enunciado: en un mes, el CAU registra 10.000 contactos: 6.000 incidencias y 4.000 peticiones. El nivel 1 resuelve 4.200 incidencias en el primer contacto y escala 1.800. Se reabren 210 tiques. El 92 % de las incidencias críticas se resolvió dentro del plazo del SLA. Calcule la FCR, la tasa de escalado y la tasa de reapertura sobre incidencias, e interprete el resultado. **Solución**: - **FCR** = 4.200 / 6.000 = **70 %**. - **Tasa de escalado** = 1.800 / 6.000 = **30 %** (complementaria de la anterior, como cabía esperar: toda incidencia o se resuelve en primer nivel o se escala). - **Tasa de reapertura** = 210 / 6.000 = **3,5 %**. **Interpretación**: una FCR del 70 % es una cifra razonable y una reapertura del 3,5 % es baja, de modo que no hay indicios de cierres prematuros; el 70 % parece, por tanto, resolución real y no aparente. El dato que **merece análisis** es el 92 % de cumplimiento en críticas: como el SLA suele comprometer un umbral superior —del orden del 95-98 % en incidencias críticas—, ese 8 % de incumplimiento en lo más grave es más preocupante que cualquiera de las otras cifras, y exige mirar caso a caso qué falló: ¿tiempos de escalado, disponibilidad de la guardia, dependencia de un proveedor cuyo UC no sostiene el SLA (§2.3.4)? Nótese también que las **4.000 peticiones** —el 40 % del volumen— son la mayor oportunidad de mejora estructural: si una parte significativa son restablecimientos de contraseña o instalaciones de software del catálogo, automatizarlas en el **nivel 0** libera capacidad del nivel 1 sin contratar a nadie.

3.3.2. Gestión del conocimiento y base de soluciones

La **gestión del conocimiento** es la práctica que convierte la experiencia acumulada en un **activo reutilizable** de la organización. En un CAU es la diferencia entre resolver el mismo caso doscientas veces desde cero y resolverlo una vez y aplicarlo doscientas.

La base de conocimiento contiene tres tipos de artículos:

1. **Artículos de resolución**: síntoma, causa, procedimiento paso a paso y verificación. Dirigidos al técnico.
2. **Errores conocidos**: problemas analizados con su causa, su rodeo y el estado de la solución definitiva (KEDB, §2.4.2).
3. **Artículos de autoservicio**: redactados **para el usuario**, en lenguaje no técnico, publicados en el portal. Son los que alimentan el nivel 0.

DATO CLAVE

Un artículo de base de conocimiento debe redactarse **desde el síntoma**, no desde la causa: el técnico que lo busca sabe lo que ve («no puedo firmar»), no lo que falla. Los artículos escritos desde la causa son invisibles en la búsqueda y por eso no se usan, por muy correctos que sean [ITIL4].

El ciclo de vida del artículo —creación, revisión, aprobación, publicación, uso, revisión periódica y retirada— es lo que distingue una base de conocimiento viva de un cementerio de documentos. Sus reglas prácticas:

- **Crear el artículo en el momento de resolver**, no «cuando haya tiempo»; el conocimiento se evapora en horas.
- **Un responsable por artículo** y una **fecha de caducidad** que fuerce su revisión.
- **Retirar activamente** lo obsoleto: un artículo caducado es peor que ninguno, porque induce a error con apariencia de autoridad.
- **Medir el uso**: qué artículos se consultan, cuáles resuelven y cuáles no se encuentran nunca. La búsqueda fallida es una fuente directa de artículos por escribir.
- **Vincular los artículos a las categorías** de la taxonomía, para que la herramienta los proponga automáticamente al clasificar el tique.

Efectos medibles de una gestión del conocimiento eficaz: sube la **FCR**, baja el **MTTR**, baja la **tasa de escalado**, se acorta la curva de aprendizaje de las incorporaciones —crítico en un servicio con rotación alta— y crece la **tasa de desvío al autoservicio**.

La mejora continua cierra el círculo del tema. ITIL 4 propone un modelo de siete pasos que puede resumirse en cuatro preguntas encadenadas: **¿cuál es la visión?**, **¿dónde estamos ahora?** (medición objetiva), **¿dónde queremos estar?** (objetivos), **¿cómo llegamos?** (acciones), seguidas de la ejecución, la comprobación de que se llegó y el mantenimiento del impulso. Es la aplicación al servicio del ciclo **planificar-hacer-verificar-actuar** que la norma ISO/IEC 20000-1 exige como sistema de gestión [ITIL4] [ISO20000].

Las **fuentes de mejora** de un CAU son cuatro, y todas han aparecido en este tema: los **indicadores** (§3.3.1), que señalan dónde duele; la **gestión de problemas** (§2.4.2), que elimina familias enteras de incidencias; la **satisfacción y las quejas** de los usuarios, que revelan lo que las métricas no capturan; y las **auditorías** de seguridad y de cumplimiento (§3.2.1), que detectan lo que la operación normaliza sin darse cuenta.

EJEMPLO DE APLICACIÓN EN EL AYTO

Cerrando el caso de referencia: la incidencia de firma de la tramitadora se resolvió en su día actualizando el middleware criptográfico. Bien gestionada, esa resolución produce cuatro salidas duraderas, y no solo un tique cerrado: **(1)** un **artículo de resolución** para el nivel 1, redactado desde el síntoma «no puedo firmar con la tarjeta»; **(2)** un **artículo de autoservicio** en el portal, para que el siguiente usuario compruebe él mismo la versión antes de llamar; **(3)** un **error conocido** en la KEDB mientras la solución definitiva se despliega a todo el parque; y **(4)** una **acción de mejora** en la plataforma de gestión centralizada, que a partir de ahora vigila la versión del middleware como elemento de configuración y avisa cuando un puesto se desvía. La incidencia deja de existir como categoría, que es la mejor manera de resolverla.

Índice de diagramas

ID	Título	Sección	Tipo
D1	Modelos de puesto de trabajo: tradicional, VDI, RDSH y DaaS	§1.1.1	Comparativa
D2	Las capas del puesto de usuario y sus incidencias típicas	§1.1.2	Capas
D3	Tres arquitecturas de conexión de control remoto	§1.2.1	Esquema de red
D4	La cadena AAA de una sesión de asistencia remota	§1.2.2	Flujo
D5	Mapa de protocolos y puertos de gestión remota	§1.3.1	Tabla visual
D6	Gestión dentro de banda frente a fuera de banda	§1.3.1	Comparativa
D7	Del canal en claro al canal tunelizado	§1.3.2	Flujo comparado
D8	Herramientas de asistencia por sistema operativo	§1.3.3	Bloques
D9	Los seis bloques de la gestión centralizada del puesto	§1.3.4	Ciclo
D10	ITIL 4, ISO/IEC 20000 y COBIT: tres marcos, tres papeles	§2.1.1	Comparativa
D11	Ciclo de vida de una incidencia: ocho etapas y sus estados	§2.1.2	Flujo
D12	El CAU: canales de entrada y niveles de soporte	§2.2	Embudo
D13	Matriz impacto × urgencia y tiempos comprometidos	§2.3.1	Matriz
D14	Escalado funcional frente a escalado jerárquico	§2.3.2	Ejes cruzados
D15	Incidencia, problema, error conocido, petición y evento	§2.4.1	Bloques
D16	El círculo completo: seguridad, medición y mejora continua	§3	Ciclo

D1 · Modelos de puesto de trabajo: tradicional, VDI, RDSH y DaaS

Sección: §1.1.1 — Entornos de escritorio tradicionales y virtualizados **Propósito**: Fijar la diferencia entre los cuatro modelos de puesto, señalando dónde se ejecuta la aplicación en cada uno y qué

consecuencia tiene para el soporte.

Cuatro modelos de puesto de trabajo

	TRADICIONAL cliente pesado (PC)	VDI 1 máquina virtual/usuario	RDSH N sesiones / 1 servidor	DaaS lo anterior, en la nube
DÓNDE SE EJECUTA LA APLICACIÓN	En el equipo del usuario	En el centro de datos	En el centro de datos	En la nube del proveedor
QUÉ VIAJA POR LA RED	Datos de aplicación	Pantalla, teclado, ratón, audio y periféricos redirigidos		
AISLAMIENTO ENTRE USUARIOS	Total (equipo propio)	Alto (SO propio)	Bajo (SO compartido)	Según la modalidad
CONSECUENCIA PARA EL SOPORTE	Equipo a equipo: parchear y reparar	Reasignar otra máquina virtual en minutos	Un usuario puede degradar a los demás	Capacidad y datos en manos del proveedor

Sin red no hay puesto en VDI, RDSH ni DaaS; el tradicional trabaja en local

[Fuente: MS-RDS; VDI-VENDORS]

D2 · Las capas del puesto de usuario y sus incidencias típicas

Sección: §1.1.2 — Componentes hardware y software del puesto de usuario **Propósito**: Mostrar el puesto como una pila de capas y asociar a cada una la familia de incidencias que genera, que es el mapa mental del diagnóstico.

El puesto de usuario, capa a capa

CAPA	INCIDENCIAS TÍPICAS	¿EN REMOTO?
Servicios corporativos	Sede caída, aplicación lenta, servicio no disponible	Sí
Conectividad	Sin VPN, proxy, resolución de nombres, permisos	Parcialmente
Identidad y permisos	Cuenta bloqueada, certificado caducado, sin permiso	Sí
Aplicaciones	Versión, complemento deshabilitado, error al abrir	Sí
Configuración y seguridad	Directiva nueva, antivirus bloquea, disco cifrado	Sí
Sistema operativo	Servicio detenido, actualización fallida, error grave	Si arranca
Firmware (UEFI, TPM)	No arranca, orden de arranque, clave de cifrado	Fuera de banda
Hardware y periféricos	No enciende, disco, monitor, lector de tarjetas, cable	No: presencial

[Fuente: ITIL4; ENS]

D3 · Tres arquitecturas de conexión de control remoto

Sección: §1.2.1 — Arquitecturas cliente-servidor y punto a punto **Propósito**: Explicar por qué las herramientas modernas usan un servidor de mediación y cómo atraviesan el NAT y el cortafuegos sin abrir puertos entrantes.



D4 · La cadena AAA de una sesión de asistencia remota

Sección: §1.2.2 — Mecanismos de autenticación, autorización y sesión **Propósito**: Ordenar los controles que deben cumplirse antes, durante y después de una sesión de control remoto, con el modelo AAA como esqueleto.

Antes, durante y después de la sesión

1 · AUTENTICACIÓN ¿quién eres?	2 · AUTORIZACIÓN ¿qué puedes hacer?	3 · SESIÓN ¿cómo se controla?	4 · REGISTRO ¿qué has hecho?
· Identidad NOMINAL · Directorio corporativo · Kerberos o clave pública · Segundo factor (MFA) · Código de sesión de un solo uso **Y TAMBIÉN:** autenticar al EQUIPO	· Perfiles por rol (RBAC) · Alcance: qué equipos · Modo: ver / controlar / ficheros / órdenes · Segregación de funciones · Elevación temporal ligada a un tique	· Consentimiento · Indicador visible · Corte por el usuario · Expiración y duración máxima · Bloqueo al desconectar · Canal cifrado extremo a extremo	· Quién, cuándo, sobre qué equipo · Tique asociado · Modo de la sesión · Ficheros y portapapeles · Elevación de privilegios · Registro íntegro y centralizado

Autenticar solo al técnico no basta: si no se verifica el equipo remoto, cabe un ataque de intermediario

Sesión sin tique asociado = acceso sin justificación: hallazgo crítico de auditoría

[Fuente: RFC2865; ENS; RFC4253]

D5 · Mapa de protocolos y puertos de gestión remota

Sección: §1.3.1 — Protocolos de nivel de aplicación para gestión remota **Propósito**: Reunir en una sola imagen los protocolos, sus puertos y su naturaleza. Es el diagrama de memorización directa del bloque técnico.

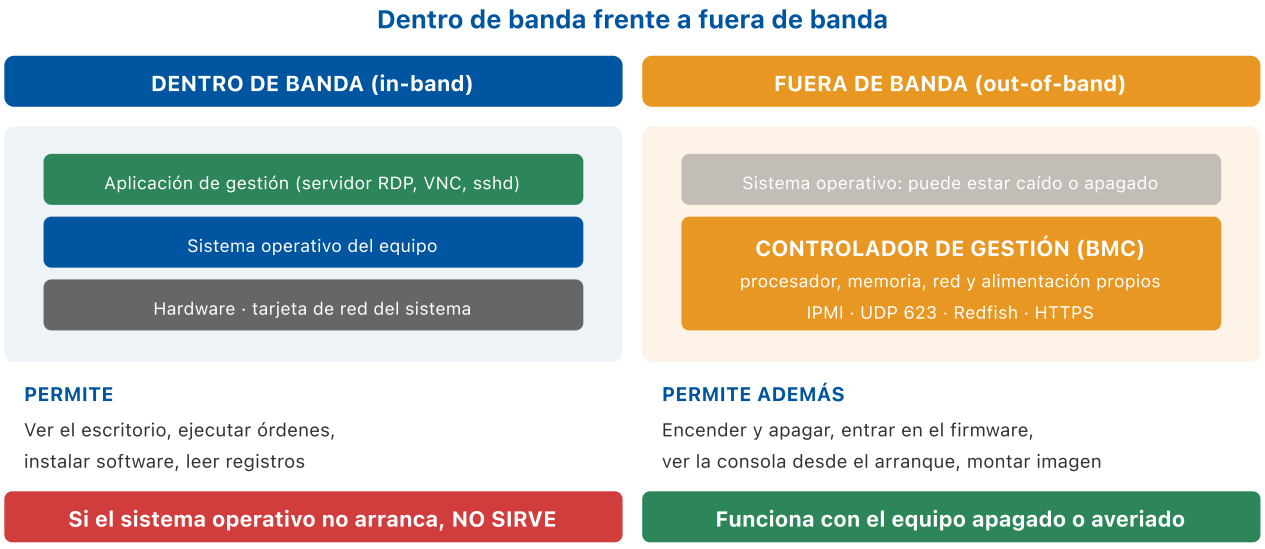
Protocolos y puertos de gestión remota

PROTOCOLO	PUERTO	QUÉ TRANSMITE	USO PRINCIPAL
RFB (VNC)	**TCP 5900+N**	Píxeles del framebuffer	Asistencia compartiendo la sesión del usuario
RDP	**TCP/UDP 3389**	Primitivas y canales	Escritorio remoto; abre sesión independiente
SSH	**TCP 22**	Texto cifrado + túneles	Administración de Unix, Linux y red
Telnet	**TCP 23**	Texto EN CLARO	Obsoleto y desaconsejado: debe estar deshabilitado
WinRM	**TCP 5985/5986**	WS-Management (DMTF)	Órdenes y automatización en Windows
SNMP	**UDP 161/162**	Consultas y avisos	Monitorización; v3 es la única con seguridad real
NETCONF	**TCP 830**	XML sobre SSH	Configuración de dispositivos de red
IPMI (BMC)	**UDP 623**	Fuera de banda	Control con el equipo apagado o el SO caído
Redfish	**TCP 443**	REST sobre HTTPS	Sucesor moderno de IPMI
X11 (reenvío)	**TCP 6000+N**	Objetos gráficos	Aplicación gráfica Unix remota, siempre sobre SSH
Wake-on-LAN	**UDP 7 / 9**	Paquete mágico	Encendido remoto para mantenimiento nocturno

[Fuente: RFC6143; MS-RDPBCGR; RFC4253; DSP0226; IPMI2]

D6 · Gestión dentro de banda frente a fuera de banda

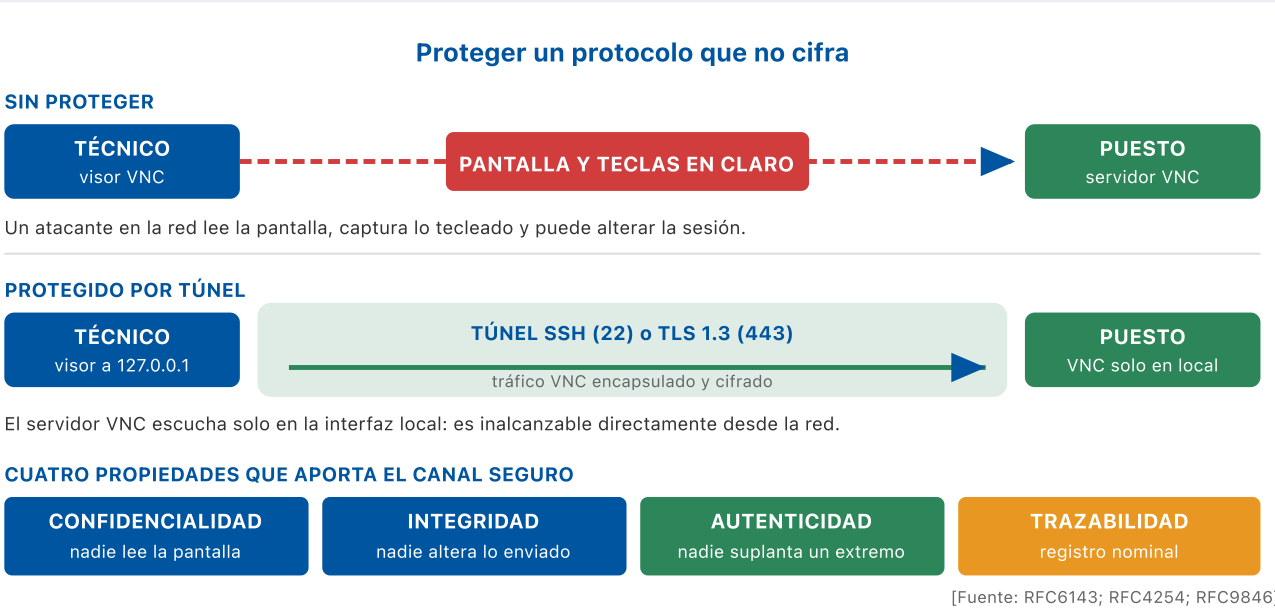
Sección: §1.3.1 — Protocolos de nivel de aplicación para gestión remota **Propósito**: Aislar la distinción que resuelve el caso típico de «el equipo no arranca y está a veinte kilómetros».



[Fuente: IPMI2; DSP0266]

D7 · Del canal en claro al canal tunelizado

Sección: §1.3.2 — Canales de comunicación seguros y cifrado **Propósito**: Mostrar por qué un protocolo sin cifrado no debe usarse desnudo y cómo se protege encapsulándolo.



[Fuente: RFC6143; RFC4254; RFC9846]

D8 · Herramientas de asistencia por sistema operativo

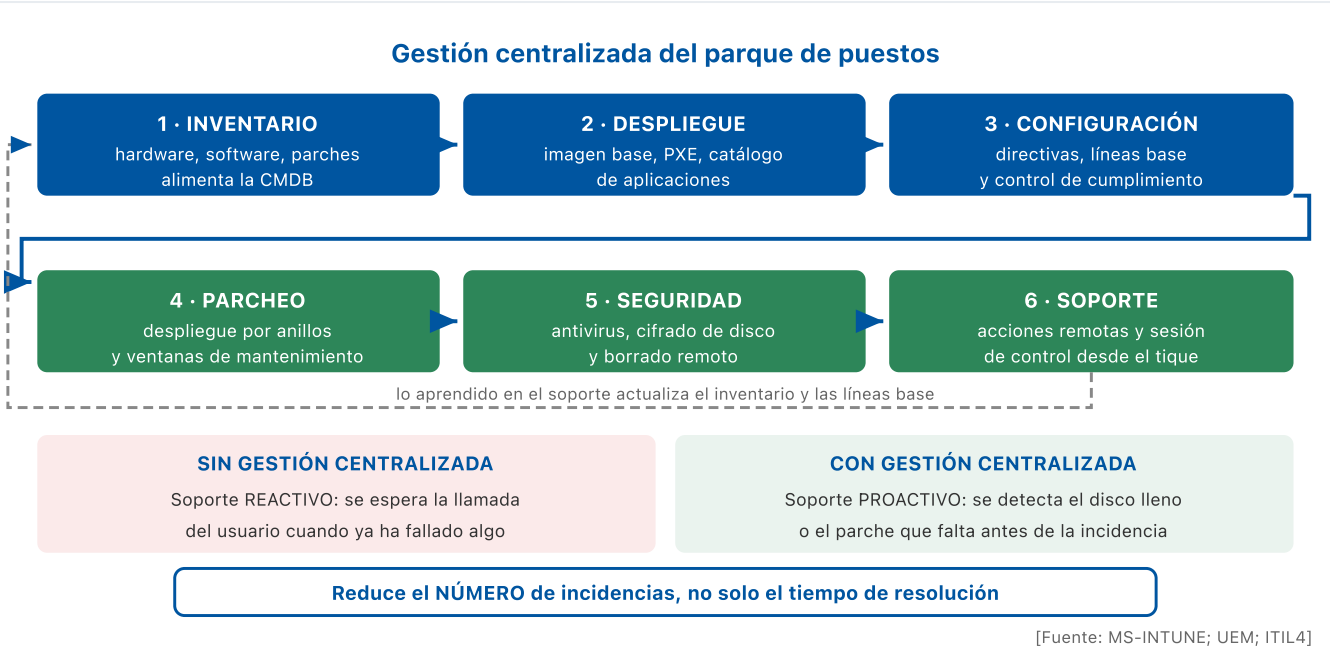
Sección: §1.3.3 — Herramientas de asistencia remota en sistemas operativos **Propósito**: Ordenar las herramientas nativas de cada sistema y, sobre todo, separar las que **comparten** la sesión del usuario (válidas para asistir) de las que abren una sesión **nueva**.



[Fuente: MS-QUICKASSIST; MS-RDS; OPENSSH; APPLE-ARD]

D9 · Los seis bloques de la gestión centralizada del puesto

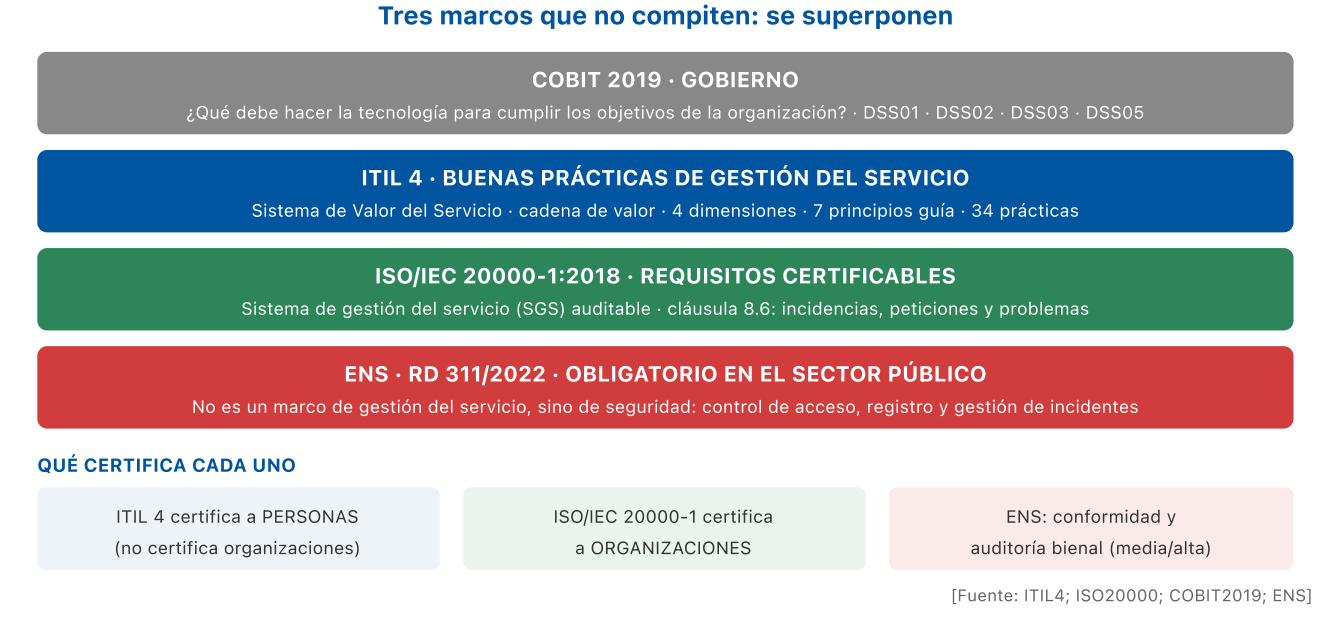
Sección: §1.3.4 — Soluciones centralizadas de gestión de puestos de trabajo **Propósito**: Presentar las funciones de una plataforma de gestión unificada del puesto como un ciclo continuo que va del inventario al soporte y vuelve a empezar.



[Fuente: MS-INTUNE; UEM; ITIL4]

D10 · ITIL 4, ISO/IEC 20000 y COBIT: tres marcos, tres papeles

Sección: §2.1.1 — Principios de ITIL aplicados a la gestión de incidencias **Propósito**: Evitar la confusión más frecuente del bloque organizativo: qué es cada marco, qué aporta y qué certifica.



[Fuente: ITIL4; ISO20000; COBIT2019; ENS]

D11 · Ciclo de vida de una incidencia: ocho etapas y sus estados

Sección: §2.1.2 — Ciclo de vida y flujos de trabajo de atención al usuario **Propósito**: Fijar la secuencia canónica del tique y señalar en qué estados se detiene el reloj del acuerdo de nivel de servicio.



[Fuente: ITIL4; ISO20000]

D12 · El CAU: canales de entrada y niveles de soporte

Sección: §2.2 — El Centro de Atención a Usuarios (CAU) **Propósito**: Mostrar el CAU como punto único de contacto que recoge todos los canales en un único registro y distribuye el trabajo entre niveles de coste creciente.



[Fuente: ITIL4; ISO20000]

D13 · Matriz impacto × urgencia y tiempos comprometidos

Sección: §2.3.1 — Priorización, impacto y urgencia · §2.3.4 — SLA **Propósito**: Unir en una imagen el cálculo de la prioridad y sus consecuencias contractuales: tiempo de respuesta, tiempo de resolución y escalado automático.

Prioridad = Impacto × Urgencia

MATRIZ 3 × 3

	URGENCIA ALTA	URGENCIA MEDIA	URGENCIA BAJA
IMPACTO ALTO	1 · CRÍTICA	2 · ALTA	3 · MEDIA
IMPACTO MEDIO	2 · ALTA	3 · MEDIA	4 · BAJA
IMPACTO BAJO	3 · MEDIA	4 · BAJA	5 · MUY BAJA

LOS DOS EJES SON INDEPENDIENTES

IMPACTO: ¿a cuánto afecta?
usuarios, criticidad, riesgo legal

URGENCIA: ¿cuánto puede esperar?
rapidez del daño, rodeo, plazo

Impacto alto ≠ prioridad crítica

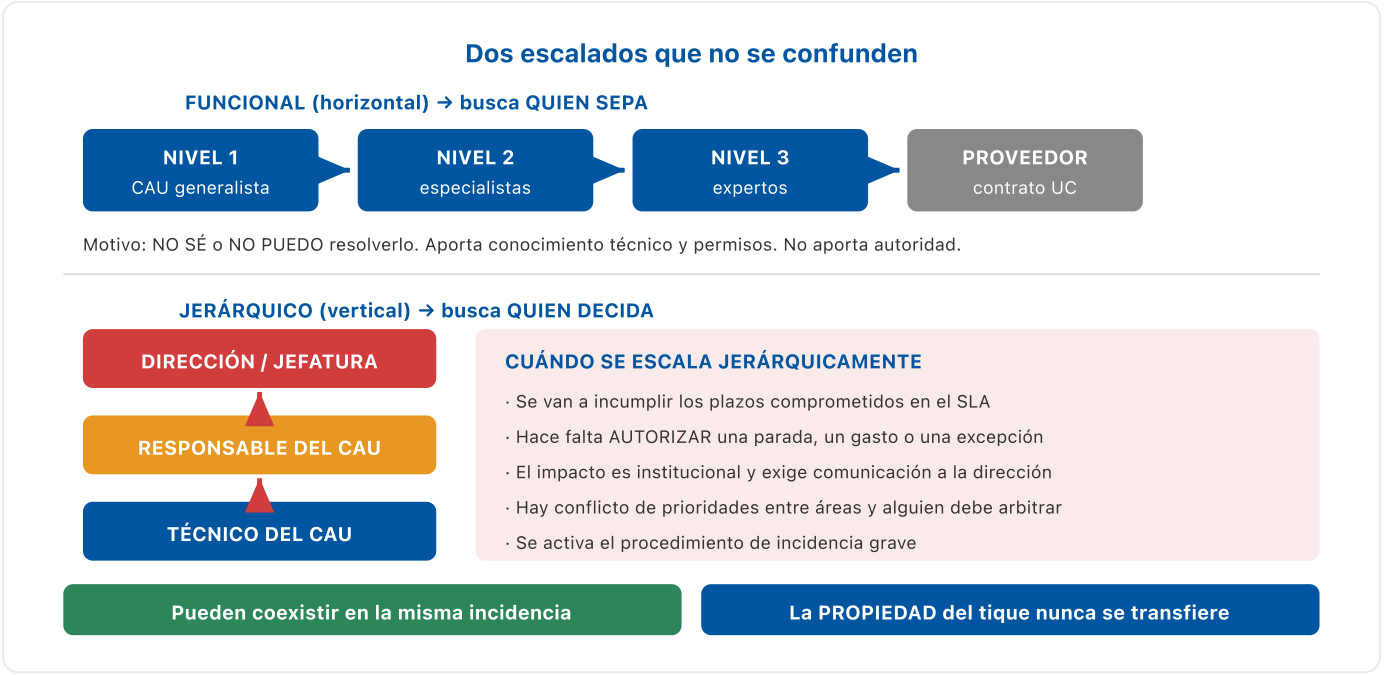
TIEMPOS COMPROMETIDOS (valores ilustrativos: se pactan en cada SLA)

PRIORIDAD	RESPUESTA	RESOLUCIÓN	ESCALADO AUTOMÁTICO
1 · Crítica	15 minutos	4 horas	N2 a los 30 min; jerárquico a la hora
2 · Alta	1 hora	8 horas laborables	N2 a las 2 h; jerárquico a las 6 h
3 · Media	4 horas	2 días laborables	N2 al día; jerárquico al segundo día
4 · Baja	1 día laborable	5 días laborables	N2 a los 3 días

La prioridad NO la decide el usuario: se aplican criterios objetivos escritos

D14 · Escalado funcional frente a escalado jerárquico

Sección: §2.3.2 — Diagnóstico, escalado funcional y jerárquico **Propósito**: Separar visualmente los dos ejes del escalado, que es una de las confusiones más frecuentes.



D15 · Incidencia, problema, error conocido, petición y evento

Sección: §2.4.1 — Diferencias entre incidencia, problema y petición **Propósito**: Fijar de una vez las cinco definiciones que más se confunden, con el criterio que las separa y un ejemplo de cada una.



D16 · El círculo completo: seguridad, medición y mejora continua

Sección: §3 — Marco normativo, seguridad y calidad en la Administración Pública **Propósito**: Cerrar el tema mostrando cómo la asistencia remota, la gestión de incidencias, el marco normativo y los indicadores forman un único ciclo que se realimenta.



[Fuente: ENS; RGPD; ITIL4; ISO20000]

Casos prácticos

Los tres casos recorren el supuesto de referencia del tema (ver la pestaña Contenido, «Convenciones»): el **CAU municipal atendiendo al puesto de trabajo de una Oficina de Atención a la Ciudadanía**. El **Caso 1** trabaja el **diagnóstico y la asistencia remota**; el **Caso 2**, la **priorización, el escalado y el acuerdo de nivel de servicio** ante una incidencia grave; y el **Caso 3**, la **seguridad, el cumplimiento normativo y la mejora continua**.

Caso 1 — Diagnóstico y asistencia remota en el puesto de una Oficina de Atención a la Ciudadanía

Enunciado

Son las 9:40 de la mañana. Una **tramitadora de una Oficina de Atención a la Ciudadanía de un distrito** llama al CAU: **no consigue firmar electrónicamente** un expediente con su certificado, alojado en una **tarjeta criptográfica**, y tiene a un vecino esperando en el mostrador. El resto de sus aplicaciones funcionan con normalidad. Su puesto es un **equipo tradicional** conectado a la red corporativa municipal, con agente de gestión instalado. En la misma oficina hay otras cinco personas que, de momento, no han informado de nada.

Cuestiones

Cuestión 1 — Registro y acotación (2 puntos). Indique los **datos mínimos** que debe recoger el técnico antes de tocar el equipo y **dos preguntas** de acotación que reorienten el diagnóstico.

Cuestión 2 — Hipótesis por capas (3 puntos). Enumere **cinco hipótesis** de causa, cada una en una capa distinta del puesto, y señale cuál de ellas **no** podría resolverse en remoto.

Cuestión 3 — Modo de asistencia (3 puntos). Justifique **qué tipo de sesión** de control remoto debe abrirse y por qué **no sirve** una conexión de escritorio remoto estándar. Enumere los **controles** que deben aplicarse durante esa sesión.

Cuestión 4 — Cierre de la actuación (2 puntos). Suponiendo que el fallo se debía a una versión desactualizada del componente criptográfico, describa cómo debe **cerrarse** la incidencia y qué debe **quedar** de ella más allá del tique cerrado.

▾ **Ver solución orientativa**

Solución orientativa

- **C1**: (§2.2.2) Datos mínimos: **identificación de la usuaria** (número de empleada, unidad, ubicación exacta y teléfono de contacto), **fecha, hora y canal** de entrada, **descripción del síntoma en sus palabras** («no me deja firmar, sale un error al pulsar Firmar»), **identificación del equipo** en el inventario y **servicio afectado** (firma electrónica en la tramitación de expedientes). Dos preguntas de acotación válidas: *¿desde cuándo ocurre y qué ha cambiado —una actualización, un traslado, un cambio de contraseña—?* y *¿le ocurre solo a usted o también a sus compañeros de la oficina?* La segunda es la más rentable: si afecta a toda la oficina, la hipótesis se desplaza a una capa compartida y el impacto sube.

- **C2**: (§1.1.2) Cinco hipótesis, una por capa:

Capa	Hipótesis	¿Remoto?
Hardware / periférico	El lector de tarjetas está desconectado o no es reconocido	**No**: puede exigir presencia o la colaboración de la usuaria
Aplicaciones	El componente criptográfico (*middleware*) está desactualizado o desinstalado	Sí
Identidad	El certificado ha caducado o ha sido revocado	Sí
Configuración y seguridad	Una directiva o el antivirus bloquean el complemento de firma del navegador	Sí
Conectividad	No se alcanza el servicio de validación de certificados de la sede	Sí

La hipótesis de la primera fila es la única que puede no admitir resolución remota, y por eso conviene descartarla pronto —basta con pedir a la usuaria que confirme que el lector está conectado y con comprobar en remoto si el sistema lo reconoce—.

- **C3**: (§1.2, §1.3.3) Debe abrirse una sesión de **asistencia atendida en modo control compartido sobre la sesión existente** de la usuaria. Una conexión de **escritorio remoto estándar por RDP no sirve** por dos razones acumuladas: abriría una **sesión nueva e independiente**, de modo que el técnico no vería el escritorio que la usuaria tiene delante ni reproduciría el fallo; y, además, **la tarjeta criptográfica y su lector están asociados a la sesión de la usuaria**, por lo que en una sesión nueva ni siquiera estarían disponibles.

Controles aplicables durante la sesión: **identificación nominal** del técnico con segundo factor; **código de sesión de un solo uso** facilitado por la usuaria como materialización del **consentimiento**; **indicador visible permanente** de que la sesión está activa; posibilidad de **corte unilateral** por la usuaria; petición expresa de que **cierre los documentos con datos de terceros** que no sean necesarios (**minimización**); **canal cifrado**; **bloqueo del puesto** al desconectar; y **registro** de la sesión asociado al número de tique.

- **C4**: (§2.3.3, §3.3.2) La incidencia se cierra **verificando técnicamente** que la firma funciona y, sobre todo, **pidiendo a la usuaria que firme el expediente pendiente** y confirme que puede trabajar: la verificación técnica y la del usuario no son la misma cosa. Se documenta en el tique **qué se hizo exactamente** y se le asigna una **categorización de cierre** (que en este caso probablemente diferirá de la de apertura). Más allá del tique cerrado deben quedar: **(1)** un **artículo de base de conocimiento** redactado **desde el síntoma** («no puedo firmar con la tarjeta»); **(2)** un **artículo de autoservicio** en el portal para que el siguiente usuario compruebe él mismo la versión antes de llamar; **(3)** la **consulta al inventario** de cuántos puestos más tienen la versión afectada, que es lo que permite decidir si estamos ante un caso aislado o ante un **problema**; y **(4)**, si hay más puestos afectados, la **apertura del problema** correspondiente.

Criterios de evaluación

Criterio	Puntos
Datos mínimos de registro completos y dos preguntas de acotación pertinentes	2
Cinco hipótesis en capas distintas e identificación correcta de la no resoluble en remoto	3
Tipo de sesión correctamente justificado, descarte razonado de RDP y controles de la sesión	3
Cierre con confirmación de la usuaria y salidas duraderas de la resolución	2

Caso 2 — Priorización, escalado y acuerdo de nivel de servicio ante una caída del servicio de firma

Enunciado

A las 10:15 el CAU ha recibido **catorce llamadas** de Oficinas de Atención a la Ciudadanía de **seis distritos distintos** con el mismo síntoma: **no se puede firmar electrónicamente** en la tramitación de expedientes. Hay ciudadanos esperando en los mostradores. Las aplicaciones internas de gestión funcionan con normalidad y el problema no se reproduce en los puestos del propio CAU.

El acuerdo de nivel de servicio vigente establece, para las incidencias **críticas**, un tiempo de respuesta de **15 minutos**, un tiempo de resolución de **4 horas** y escalado automático a nivel 2 a los **30 minutos** y jerárquico a la **hora**.

Cuestiones

Cuestión 1 — Registro y agrupación (2 puntos). Indique cómo deben tratarse las catorce llamadas y qué efecto tiene esa decisión sobre la prioridad.

Cuestión 2 — Prioridad (2 puntos). Valore el **impacto** y la **urgencia** y determine la **prioridad** justificando cada eje por separado.

Cuestión 3 — Escalados (3 puntos). Indique **qué escalados** procede activar, de qué tipo es cada uno, a quién se dirige y **qué información** debe acompañarlos.

Cuestión 4 — Comunicación y cierre del ciclo (3 puntos). Describa las obligaciones de **comunicación** durante la incidencia y qué debe ocurrir **después** de restablecer el servicio.

▾ Ver solución orientativa

Solución orientativa

- **C1**: (§2.3.1) Las catorce llamadas **no** son catorce incidencias independientes ni deben descartarse como duplicados sin registro. Cada contacto se **registra** —hay catorce usuarios que esperan respuesta— pero todos se **vinculan a una única incidencia** que representa el fallo del servicio, con los catorce como afectados. La agrupación tiene dos efectos: **eleva el impacto** de «un usuario» a «varias unidades de atención al ciudadano de seis distritos», y permite **comunicar de una sola vez** a todos los afectados cuando se restablezca el servicio.
- **C2**: (§2.3.1) **Impacto ALTO**: está afectado un servicio esencial —la firma electrónica en la tramitación—, en múltiples unidades y distritos, con **interrupción de la atención al**

ciudadano y con posible afectación a plazos administrativos. **Urgencia ALTA**: el daño se está produciendo ahora mismo, hay vecinos esperando en el mostrador y **no consta un rodeo** disponible. Cruzando ambos ejes en la matriz, **prioridad 1 — crítica**. Además, por número de afectados, criticidad del servicio e impacto en la atención al ciudadano, se cumplen los criterios para activar el **procedimiento de incidencia grave**, que no es lo mismo que la prioridad 1: es un flujo con procedimiento propio.

- **C3**: (§2.3.2) Procede activar **los dos escalados, y simultáneamente**:

- **Escalado funcional (horizontal)** al equipo de **administración electrónica o de la plataforma de firma**: el fallo no está en el puesto —no se reproduce en los puestos del CAU, afecta a seis distritos a la vez y solo a un servicio— sino en un componente central o en un despliegue reciente sobre el parque. El primer nivel no tiene ni el conocimiento ni los permisos necesarios. Motivo: *no sé o no puedo resolverlo*.
- **Escalado jerárquico (vertical)** al **responsable del CAU** y, a través de él, a la dirección: hay que **activar el procedimiento de incidencia grave**, designar un responsable de la incidencia, decidir sobre una eventual comunicación institucional y, en su caso, autorizar una parada o una reversión de emergencia. Motivo: *hace falta quien decida y quien aporte recursos*. Nótese que este escalado **no aporta conocimiento técnico**.

Información que debe acompañar a ambos: **síntoma exacto**, **alcance confirmado** (catorce avisos, seis distritos, un solo servicio afectado), **hora de inicio**, **comprobaciones ya realizadas y descartadas** (no se reproduce en el CAU, el resto de aplicaciones funciona), **cambios recientes** consultados en el registro de cambios, y **qué se pide** exactamente a cada destinatario. La **propiedad del tique sigue siendo del CAU**, que continúa siendo responsable del seguimiento y de informar a los usuarios.

- **C4**: (§2.1.2, §2.3.3, §2.4.2) **Durante** la incidencia: comunicación **proactiva y periódica** a las oficinas afectadas —que necesitan poder decir algo al ciudadano que espera—, con una previsión realista y actualizaciones a intervalos fijos aunque no haya novedades; información a la dirección por el canal jerárquico; y aviso al resto del CAU para que las llamadas nuevas se vinculen a la incidencia existente en lugar de abrir tiques sueltos. **Después** del restablecimiento: **confirmar con una muestra de usuarios** que efectivamente pueden firmar antes de dar por resuelta la incidencia; **comunicar el cierre** a todos los afectados; realizar la **revisión posterior** propia del procedimiento de incidencia grave; **abrir el problema** correspondiente si el servicio se restableció con un rodeo o si la causa raíz no está determinada; **documentar el error conocido** y su rodeo en la KEDB mientras la solución definitiva se despliega; y tramitar esa solución definitiva a través de la **gestión de cambios**, con evaluación de riesgo, ventana y plan de reversión. Finalmente, revisar si el **SLA se cumplió** y, si no, analizar por qué: puede ser un problema

de tiempos de escalado, de disponibilidad de la guardia o de un contrato de soporte que no sostiene el compromiso.

Criterios de evaluación

Criterio	Puntos
Registro de los catorce contactos con vinculación a una única incidencia y efecto sobre el impacto	2
Impacto y urgencia justificados por separado, prioridad correcta y mención del flujo de incidencia grave	2
Los dos escalados identificados, correctamente tipificados y con la información que deben llevar	3
Comunicación durante la incidencia y cierre del ciclo con problema, error conocido y cambio	3

Caso 3 — Seguridad, cumplimiento normativo y mejora continua del servicio de asistencia

Enunciado

El Ayuntamiento va a **licitar** el servicio de soporte al puesto de trabajo, que incluye asistencia remota **atendida y desatendida** sobre todo el parque municipal. La herramienta propuesta por uno de los licitadores es un **servicio en la nube** con servidor de mediación del propio fabricante y **grabación en vídeo** de todas las sesiones. El sistema al que dan soporte los puestos trata **expedientes con datos personales de ciudadanos**.

Durante una prueba piloto se detecta, además, que **varios técnicos comparten una misma cuenta** para conectarse a los puestos y que **el 18 % de las sesiones registradas no tiene un tique asociado**.

Cuestiones

Cuestión 1 — Hallazgos del piloto (3 puntos). Analice los dos hallazgos detectados, indicando qué principio o requisito incumple cada uno y cómo se corrige.

Cuestión 2 — Requisitos del ENS (3 puntos). Indique la **categoría** previsible del sistema y **cuatro requisitos** derivados del Esquema Nacional de Seguridad que deben exigirse en el pliego.

Cuestión 3 — Protección de datos (2 puntos). Analice la propuesta del licitador desde la perspectiva del RGPD, con especial atención al servidor de mediación en la nube y a la grabación de sesiones.

Cuestión 4 — Indicadores (2 puntos). Proponga **cuatro indicadores** para el seguimiento del contrato y explique por qué deben equilibrarse entre sí.

▾ Ver solución orientativa

Solución orientativa

- **C1**: (§3.1.1, §3.1.2)
- **Cuentas compartidas**: incumplen la exigencia de **identificación nominal** y, con ella, la dimensión de **trazabilidad** del ENS: las actuaciones dejan de ser atribuibles a una persona determinada, de modo que ni puede auditarse ni puede exigirse responsabilidad. Corrección: **cuentas nominales** para cada técnico, provenientes del directorio corporativo, con **autenticación multifactor** para el perfil con capacidad de control remoto, separación entre la cuenta ofimática y la de administración, y **perfiles por rol (RBAC)** con alcance limitado al conjunto de equipos que a cada uno le corresponde.
- **Sesiones sin tique asociado**: revelan **accesos sin justificación registrada**, es decir, sin causa documentada que legitime el tratamiento. Es el hallazgo de auditoría más significativo en este ámbito, y afecta a la vez al ENS (trazabilidad) y al RGPD (**limitación de la finalidad**). Corrección: configurar la herramienta para que **exija un tique válido** como condición para iniciar la sesión, y establecer una **revisión periódica** de las sesiones sin tique, de los accesos desatendidos y de los accesos fuera de horario, con alertas ante patrones anómalos.
- **C2**: (§3.2.1) Al tratar **expedientes con datos personales de ciudadanos**, el sistema alcanzará al menos **nivel medio** en confidencialidad, integridad y trazabilidad, lo que sitúa la **categoría en MEDIA o superior** —la categoría la fija el nivel más alto de cualquier dimensión—. Cuatro requisitos exigibles en el pliego (bastan cuatro; se enumeran seis posibles):

1. **Conformidad con el ENS del propio proveedor**, acreditada mediante certificación, dado que las obligaciones se trasladan **contractualmente** a la cadena de suministro.
2. **Control de acceso** conforme al marco operacional: identificación nominal, requisitos de acceso, **segregación de funciones**, gestión reglada de derechos y mecanismos de autenticación reforzados.

3. **Registro de la actividad** de todas las sesiones, con **protección de los registros** frente a manipulación —incluida la del administrador—, centralización en un sistema independiente, sincronización horaria común y plazo de conservación definido.
4. **Protección de las comunicaciones**: cifrado del canal, autenticidad e integridad, y **separación de la red de gestión** respecto de la red de usuarios.
5. **Gestión de incidentes de seguridad** con procedimiento documentado y criterios de **notificación al CCN-CERT**.
6. **Auditoría bienal** del sistema y compromiso del proveedor de someterse a ella y de subsanar los hallazgos.

- **C3**: (§3.2.2) El proveedor actúa como **encargado del tratamiento** (art. 28 RGPD), por lo que debe suscribirse un **contrato de encargo** que fije objeto, duración, finalidad, tipo de datos, obligaciones de seguridad, régimen de **subcontratación** y devolución o supresión al terminar. Respecto del **servidor de mediación en la nube**: todo el tráfico de las sesiones —es decir, las pantallas de los puestos municipales— pasaría por infraestructura del fabricante, lo que obliga a analizar **dónde se tratan y almacenan los datos** y, si están fuera del Espacio Económico Europeo, la **base de la transferencia internacional**; la alternativa preferible y habitual en el sector público es exigir el **despliegue del servidor de mediación en las instalaciones del Ayuntamiento** o su alojamiento en la Unión Europea. Respecto de la **grabación de todas las sesiones**: es desproporcionada como configuración por defecto, porque captura la pantalla del empleado con su correo, sus documentos y datos personales de terceros. Su implantación exige **base jurídica**, **información previa** al personal y a la representación de los trabajadores (arts. 87-91 LOPDGDD, derecho a la intimidad frente al uso de dispositivos digitales), **finalidad limitada** a la auditoría de seguridad y no al control laboral encubierto, **plazo de conservación** definido, cifrado y acceso restringido a los auditores. Lo proporcionado es **grabar solo los accesos de mayor privilegio y los desatendidos**, y aplicar la **protección de datos desde el diseño y por defecto** (art. 25 RGPD): consentimiento obligatorio en la asistencia atendida, indicador visible y transferencia de ficheros deshabilitada de fábrica.

- **C4**: (§3.3.1) Cuatro indicadores adecuados: **(1) FCR**, resolución en primer contacto, que mide la eficacia y el coste del modelo; **(2) cumplimiento del SLA**, informado **por separado para respuesta y para resolución** y **segmentado por prioridad**, porque la media global oculta el comportamiento en lo crítico; **(3) tasa de reapertura**, que detecta cierres prematuros; y **(4) CSAT** o satisfacción declarada tras la resolución. Deben **equilibrarse entre sí** porque cualquier indicador aislado puede maximizarse a costa del servicio: medir solo el volumen resuelto por técnico premia cerrar rápido y mal, y por eso la productividad se contrasta con la reapertura y con la satisfacción; medir solo el cumplimiento del SLA incentiva abusar del estado «en espera del usuario» para detener el

reloj. Como indicador adicional de madurez conviene incluir la **proporción de trabajo proactivo** —procedente de eventos de advertencia— frente al reactivo, y la **tasa de desvío al autoservicio**, que mide si la gestión del conocimiento está funcionando.

Criterios de evaluación

Criterio	Puntos
Los dos hallazgos analizados con el requisito incumplido y su corrección concreta	3
Categoría previsible justificada y cuatro requisitos del ENS correctamente exigidos	3
Encargo de tratamiento, ubicación del servidor de mediación y proporcionalidad de la grabación	2
Cuatro indicadores pertinentes y explicación razonada de su equilibrio	2

Fuentes

Tier 1 — Especificaciones, marcos de referencia y normativa

ID	Referencia
[RFC6143]	IETF. *RFC 6143: The Remote Framebuffer Protocol* (2011). Especificación del protocolo **RFB**, base de VNC: transmisión de *framebuffer* (píxeles) y eventos de teclado y ratón. Puerto de referencia TCP 5900.
[RFC4251]	IETF. *RFC 4251: The Secure Shell (SSH) Protocol Architecture* (2006). Arquitectura de SSH en tres capas: transporte, autenticación y conexión.
[RFC4252]	IETF. *RFC 4252: The Secure Shell (SSH) Authentication Protocol*. Métodos de autenticación: contraseña, clave pública, *host-based*.
[RFC4253]	IETF. *RFC 4253: The Secure Shell (SSH) Transport Layer Protocol*. Intercambio de claves, cifrado, integridad y autenticación del servidor. Puerto TCP 22.
[RFC4254]	IETF. *RFC 4254: The Secure Shell (SSH) Connection Protocol*. Multiplexación de canales, sesiones interactivas y **reenvío de puertos** (*port forwarding*, túneles).
[RFC9846]	IETF. *RFC 9846: The Transport Layer Security (TLS) Protocol Version 1.3* (julio de 2026). Obsoleta los RFC 5077, 5246, 6961, 7627, 8422 y 8446: es la especificación vigente de TLS 1.3 y sustituye a la de 2018. Cifrado del canal de las herramientas de asistencia remota y de las consolas web de gestión.
[RFC8446]	IETF. *RFC 8446: The Transport Layer Security (TLS) Protocol Version 1.3* (agosto de 2018). Obsoletado por el RFC 9846. Se conserva la referencia porque es la que recogen los temarios al uso.
[RFC5280]	IETF. *RFC 5280: Internet X.509 Public Key Infrastructure Certificate and CRL Profile*. Certificados usados para autenticar servidores de mediación, agentes y puestos.
[RFC4120]	IETF. *RFC 4120: The Kerberos Network Authentication Service (V5)*. Autenticación mediante tiques (TGT/TGS) en dominios corporativos. Puerto 88.
[RFC45	IETF. *RFC 4511: Lightweight Directory Access Protocol (LDAP): The Protocol*. Directorio corporativo de identidades y grupos. Puertos 389 y 636 (sobre TLS).

ID	Referencia
`11]`	
`[RFC2865]`	IETF. *RFC 2865: Remote Authentication Dial In User Service (RADIUS)* y *RFC 2866 (Accounting)*. Modelo **AAA**: autenticación, autorización y contabilidad/registro.
`[RFC3411]`	IETF. *RFC 3411-3418: An Architecture for Describing SNMP Management Frameworks* (SNMPv3). Gestión y monitorización remota de dispositivos. Puertos UDP 161 (consultas) y 162 (*traps*).
`[RFC6241]`	IETF. *RFC 6241: Network Configuration Protocol (NETCONF)*. Configuración remota de dispositivos sobre SSH (puerto 830).
`[RFC9110]`	IETF. *RFC 9110: HTTP Semantics* (2022). Base de las consolas de gestión y de las API REST de las plataformas ITSM.
`[RFC862]`	IETF. *RFC 862: Echo Protocol* y *RFC 863: Discard Protocol*. Puertos UDP 7 y 9, usados convencionalmente como destino del paquete mágico de **Wake-on-LAN**.
`[DSP0226]`	DMTF. *Web Services for Management (WS-Management) Specification, DSP0226*. Estándar de gestión remota sobre servicios web, implementado por **WinRM**.
`[DSP0266]`	DMTF. *Redfish Scalable Platforms Management API Specification, DSP0266*. Gestión **fuera de banda** (*out-of-band*) sobre HTTPS/REST, sucesora de IPMI.
`[IPMI2]`	Intel/HP/NEC/Dell. *Intelligent Platform Management Interface Specification v2.0*. Gestión fuera de banda a través del controlador **BMC**, con el equipo apagado. Puerto UDP 623.
`[ITIL4]`	Axelos/PeopleCert. *ITIL 4 Foundation: ITIL 4 Edition* — Sistema de Valor del Servicio (SVS), cadena de valor, cuatro dimensiones, siete principios guía y las 34 **prácticas**, entre ellas *Service desk*, *Gestión de incidencias*, *Gestión de peticiones de servicio*, *Gestión de problemas*, *Monitorización y gestión de eventos*, *Gestión de niveles de servicio*, *Gestión del conocimiento* y *Mejora continua*.
`[ITILV`	Axelos. *ITIL Service Operation (edición 2011)*. Versión anterior del marco, en la que la gestión de incidencias es un **proceso** y el *Service Desk* una **función**; sigue siendo referencia habitual

ID	Referencia
3]	en temarios y pliegos.
[ISO20000]	ISO/IEC 20000-1:2018. *Tecnología de la información — Gestión del servicio — Parte 1: Requisitos del sistema de gestión del servicio (SGS)*. Norma **certificable**; su cláusula 8.6 (resolución y cumplimiento) exige gestión de incidencias, de peticiones de servicio y de problemas.
[ISO27001]	ISO/IEC 27001:2022 e ISO/IEC 27002:2022. *Sistemas de gestión de la seguridad de la información* y catálogo de controles (control de accesos, registro de eventos, gestión de incidentes de seguridad de la información).
[COBIT2019]	ISACA. *COBIT 2019 Framework: Governance and Management Objectives*. Objetivos **DSS01** (gestionar operaciones), **DSS02** (gestionar peticiones de servicio e incidentes), **DSS03** (gestionar problemas) y **DSS05** (gestionar servicios de seguridad).
[ENS]	Real Decreto **311/2022, de 3 de mayo**, por el que se regula el **Esquema Nacional de Seguridad**. Principios básicos, requisitos mínimos, dimensiones de seguridad, categorización de sistemas y medidas del Anexo II (marco organizativo, marco operacional y medidas de protección).
[CCN-STIC]	Centro Criptológico Nacional. *Guías CCN-STIC serie 800* — en particular **803** (valoración de sistemas), **804** (implantación del ENS) y **817** (gestión de ciberincidentes: taxonomía, peligrosidad e impacto, y notificación al CCN-CERT).
[RGPD]	Reglamento (UE) **2016/679** (RGPD). Principios del art. 5 (minimización, limitación de la finalidad, integridad y confidencialidad), art. 25 (protección desde el diseño y por defecto), art. 28 (encargado del tratamiento), art. 30 (registro de actividades), art. 32 (seguridad del tratamiento) y arts. 33-34 (notificación de brechas).
[LOPDGDD]	Ley Orgánica **3/2018**, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales. Deber de confidencialidad y derechos digitales en el ámbito laboral (arts. 87-91: intimidad frente al uso de dispositivos digitales, desconexión digital, intimidad frente a la videovigilancia y la geolocalización, y derechos digitales en la negociación colectiva).
[ENI]	Real Decreto **4/2010**, de 8 de enero, por el que se regula el **Esquema Nacional de Interoperabilidad**, y sus Normas Técnicas de Interoperabilidad.
[L39-	Ley **39/2015**, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas. Derecho de la ciudadanía a relacionarse electrónicamente y a ser

ID	Referencia
`2015]`	asistida en el uso de medios electrónicos.
`[L40-2015]`	Ley **40/2015**, de 1 de octubre, de Régimen Jurídico del Sector Público. Título preliminar, capítulo V: funcionamiento electrónico del sector público (sede, firma, archivo, seguridad e interoperabilidad).

Tier 2 — Herramientas, productos y guías concretas

ID	Referencia
`[MS-RDPBCGR]`	Microsoft. *Remote Desktop Protocol: Basic Connectivity and Graphics Remoting (MS-RDPBCGR)*, Open Specifications. Protocolo **RDP**, puerto TCP/UDP 3389, canales virtuales y redirección de dispositivos.
`[MS-RDS]`	Microsoft. *Remote Desktop Services documentation* — sesiones, *Connection Broker*, *RD Gateway* (RDP sobre HTTPS), escritorios y aplicaciones publicadas. learn.microsoft.com.
`[MS-QUICKASSIST]`	Microsoft. *Quick Assist (Asistencia rápida)* y *Windows Remote Assistance*: asistencia **atendida** con código de sesión y consentimiento explícito del usuario.
`[MS-WINRM]`	Microsoft. *Windows Remote Management (WinRM)* y *PowerShell Remoting*. Implementación de WS-Management; puertos TCP 5985 (HTTP) y 5986 (HTTPS).
`[MS-INTUNE]`	Microsoft. *Microsoft Intune* y *Microsoft Configuration Manager (SCCM/MECM)*: inventario, despliegue de software, líneas base de configuración, parcheo y asistencia remota integrada.
`[MS-GPO]`	Microsoft. *Group Policy (directivas de grupo)* y *Active Directory Domain Services*: configuración centralizada del puesto y de los permisos de escritorio remoto.
`[OPENSSH]`	The OpenBSD Project. *OpenSSH Manual Pages* (`ssh` , `sshd` , `sshd_config` , `ssh-keygen` , `scp` , `sftp`). Implementación de referencia de SSH en sistemas Unix y Linux.
`[TIGERVNC]`	TigerVNC / RealVNC / x11vnc. Documentación de implementaciones del protocolo RFB y de sus modos de acceso (sesión de consola compartida frente a sesión virtual independiente).
`[XRDP]`	Proyectos *xrdp* y *X2Go*. Acceso a escritorios Linux mediante RDP o mediante el protocolo NX sobre SSH.
`[X11]`	X.Org Foundation. *X Window System Protocol, versión 11*. Modelo cliente-servidor **invertido** y reenvío de X11 sobre SSH (`ssh -X`). Puertos TCP 6000+N.
`[SPICE]`	Red Hat. *SPICE (Simple Protocol for Independent Computing Environments)*. Protocolo de acceso a escritorios de máquinas virtuales.
`[APPLE-ARD]`	Apple. *Apple Remote Desktop* y *Compartir pantalla* (basado en VNC/RFB con extensiones de autenticación de Apple).

ID	Referencia
`[VDI-VENDORS]`	Documentación de plataformas de virtualización del puesto: *Citrix Virtual Apps and Desktops* (protocolo ICA/HDX), *VMware Horizon* (Blast/PCoIP) y *Azure Virtual Desktop*. Citadas como ejemplos de VDI, RDSH y DaaS.
`[UEM]`	Documentación de plataformas de gestión unificada de dispositivos (**UEM/MDM**) y de inventario y despliegue: Intune, Jamf, Ivanti, GLPI con FusionInventory, OCS Inventory.
`[ANSIBLE]`	Red Hat. *Ansible Documentation* — gestión de configuración **sin agente** sobre SSH (Linux) o WinRM (Windows), con idempotencia. Alternativas: Puppet, Chef, Salt.
`[ITSM-TOOLS]`	Documentación de herramientas ITSM de registro y seguimiento de incidencias: ServiceNow, Jira Service Management, GLPI, Znuny/OTRS, BMC Remedy. Citadas como ejemplo de implementación de las prácticas de ITIL.
`[NAGIOS]`	Documentación de plataformas de monitorización y gestión de eventos: Nagios, Zabbix, Prometheus, Grafana. Origen de las incidencias detectadas automáticamente.
`[WSUS]`	Microsoft. *Windows Server Update Services* y equivalentes en Linux (repositorios internos, `apt` / `dnf` con réplica local). Distribución controlada de actualizaciones al puesto.
`[TPM20]`	Trusted Computing Group. *TPM 2.0 Library Specification*. Módulo de plataforma segura del puesto: almacenamiento de claves, cifrado de disco y arranque medido.
`[UEFI]`	UEFI Forum. *Unified Extensible Firmware Interface Specification* — arranque seguro (*Secure Boot*) y arranque por red **PXE** para el aprovisionamiento del puesto.

Tier 3 — Marco administrativo y organizativo (contexto)

ID	Referencia
`[IAM-MAD]`	Organismo Autónomo **Informática del Ayuntamiento de Madrid (IAM)** — organismo responsable de los sistemas de información y del soporte al puesto de trabajo municipal. Contexto institucional de los ejemplos del tema.
`[ROGA]`	Reglamento Orgánico del Gobierno y de la Administración del Ayuntamiento de Madrid, de 31 de mayo de 2004. Áreas de Gobierno y Distritos: estructura sobre la que se distribuye el parque de puestos de usuario. Ver Temas 3 y 4.
`[TRANSP-MAD]`	Portal de Transparencia y sede electrónica del Ayuntamiento de Madrid. Servicios electrónicos municipales a los que da soporte el puesto de usuario.
`[BOAM 10032]`	BOAM 10.032 (23-dic-2025). Bases específicas TIC C1 Ayto. Madrid — temario oficial y estructura del ejercicio.

Las referencias Tier 1 fijan el fundamento del tema por sus dos mitades: por el lado técnico, las especificaciones de los protocolos con los que se toma control de un puesto o se gestiona a distancia (RFB, SSH, TLS, Kerberos, LDAP, SNMP, WS-Management, Redfish/IPMI); por el lado organizativo, los marcos canónicos de gestión de servicios TI (ITIL 4, ISO/IEC 20000-1, COBIT 2019) y la normativa española que condiciona cualquier asistencia remota en el sector público (ENS, RGPD y LOPDGDD). Tier 2 documenta productos y herramientas concretas —RDP, VNC, OpenSSH, WinRM, Intune, plataformas VDI y suites ITSM— citadas como ejemplos sin que el tema dependa de ninguna en particular; el opositor debe reconocer el mecanismo, no memorizar una marca. Tier 3 sitúa el supuesto municipal: el IAM como responsable del soporte al puesto de trabajo del Ayuntamiento de Madrid y los servicios electrónicos a los que ese puesto da servicio.